🌐 Module 03: Open Source Intelligence (OSINT) and Attack Surface Mapping

```
# Exercise 1: Collecting Open-source Intelligence (OSINT) on Target's Domain Name
```

Scenario

Penetration testing is much more than just running exploits against vulnerable systems. A penetration test begins before penetration testers have even contacted the victim's systems. Rather than blindly throwing out exploits and praying that one of them returns a shell, a penetration tester meticulously studies the environment for potential weaknesses and their mitigating factors. By the time a penetration tester runs an exploit, he or she is nearly certain that it will be successful. Since failed exploits can in some cases cause a crash or even damage to the target system, or at the very least make the target un-exploitable in the future, penetration testers won't get the best results, or deliver the most thorough report to their clients, if they blindly turn an automated exploit machine on the target network with no preparation.

The importance of open-source intelligence (OSINT) in penetration testing lies in its ability to uncover publicly available information that attackers might exploit. By leveraging OSINT techniques, penetration testers can gather critical insights about an organization's infrastructure, employees, and potential vulnerabilities without direct engagement. This process aids in identifying security gaps, such as exposed credentials, misconfigured assets, or sensitive data leaks, that may otherwise go unnoticed. Furthermore, the use of OSINT ensures a comprehensive reconnaissance phase, enabling testers to simulate real-world attack scenarios while adhering to ethical and legal boundaries. This proactive approach helps organizations fortify their defenses and mitigate risks effectively.

A penetration tester collects information about a company, such as internal and external links to the company's website, people working in the company, geographical location, DNS information, competitive intelligence, network range, etc. This information is collected to search for vulnerabilities and exploit and sniff valuable information. To become an expert penetration tester and security auditor, you must know various techniques to gather a company's information.

Objective

The objective of this lab is to help students learn different techniques to gather information about a company; you will learn how to:
- Collect Open-source Intelligence (OSINT) on Target's Domain Name
- Collect OSINT about Target on the Web
- Collect OSINT on Target's Employees
- Perform Open Source Intelligence (OSINT) using Automation Tools
- Identify and Map Attack Surface

> **NOTE:** All lab manuals are accessible in the **Lab Manuals** folder located on the Desktop of the machines. Please refer to the respective lab manual if you need to copy and paste any commands or code during the lab sessions.

Task 1: Performing Whois Lookups

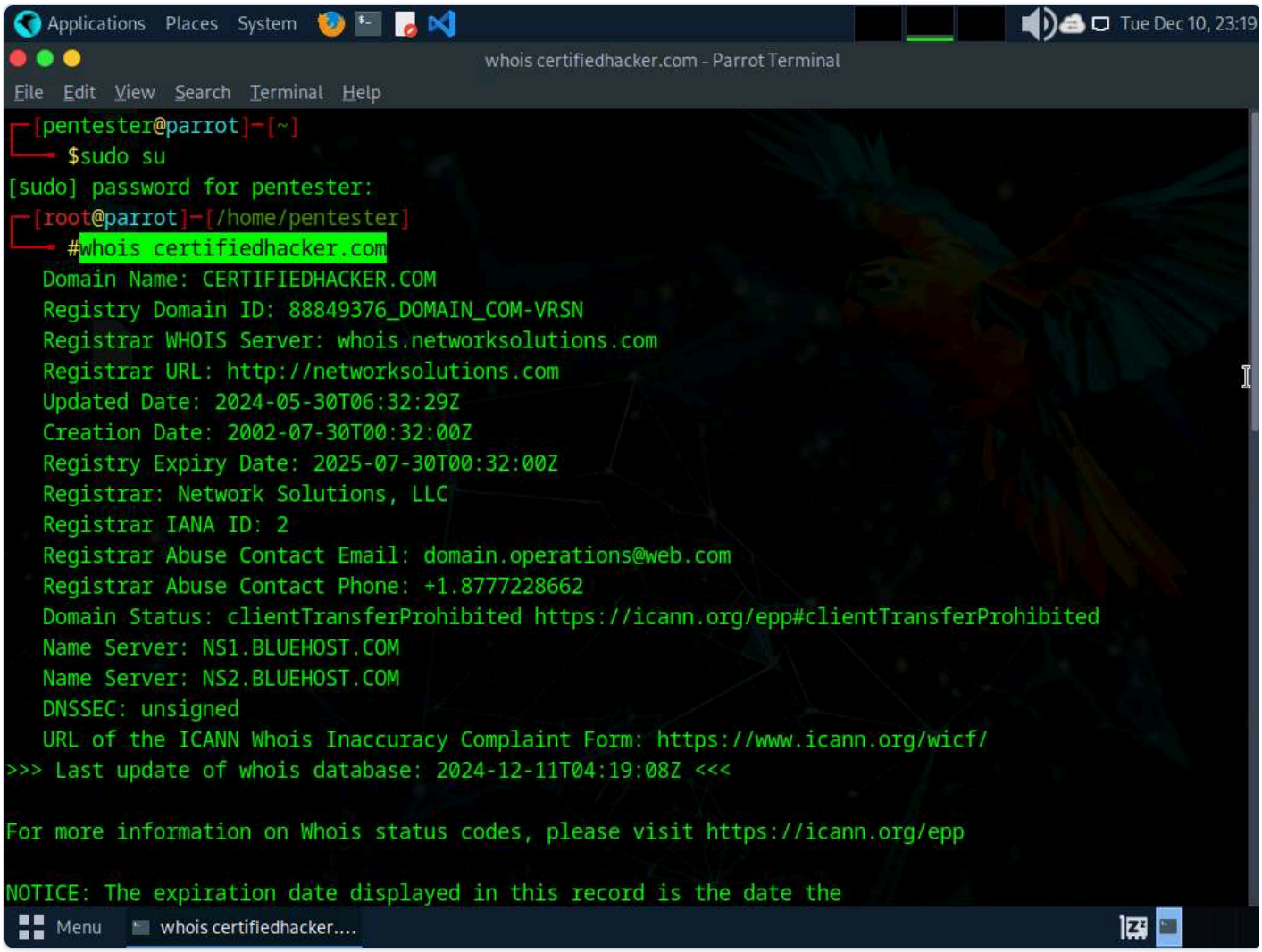
Whois Lookup provides domain registration details, including the domain owner, registration and expiration dates, contact information, and name servers. Whois information helps in mapping the target's network infrastructure,

uncovering potential vulnerabilities, and extracting administrative and technical contact details.

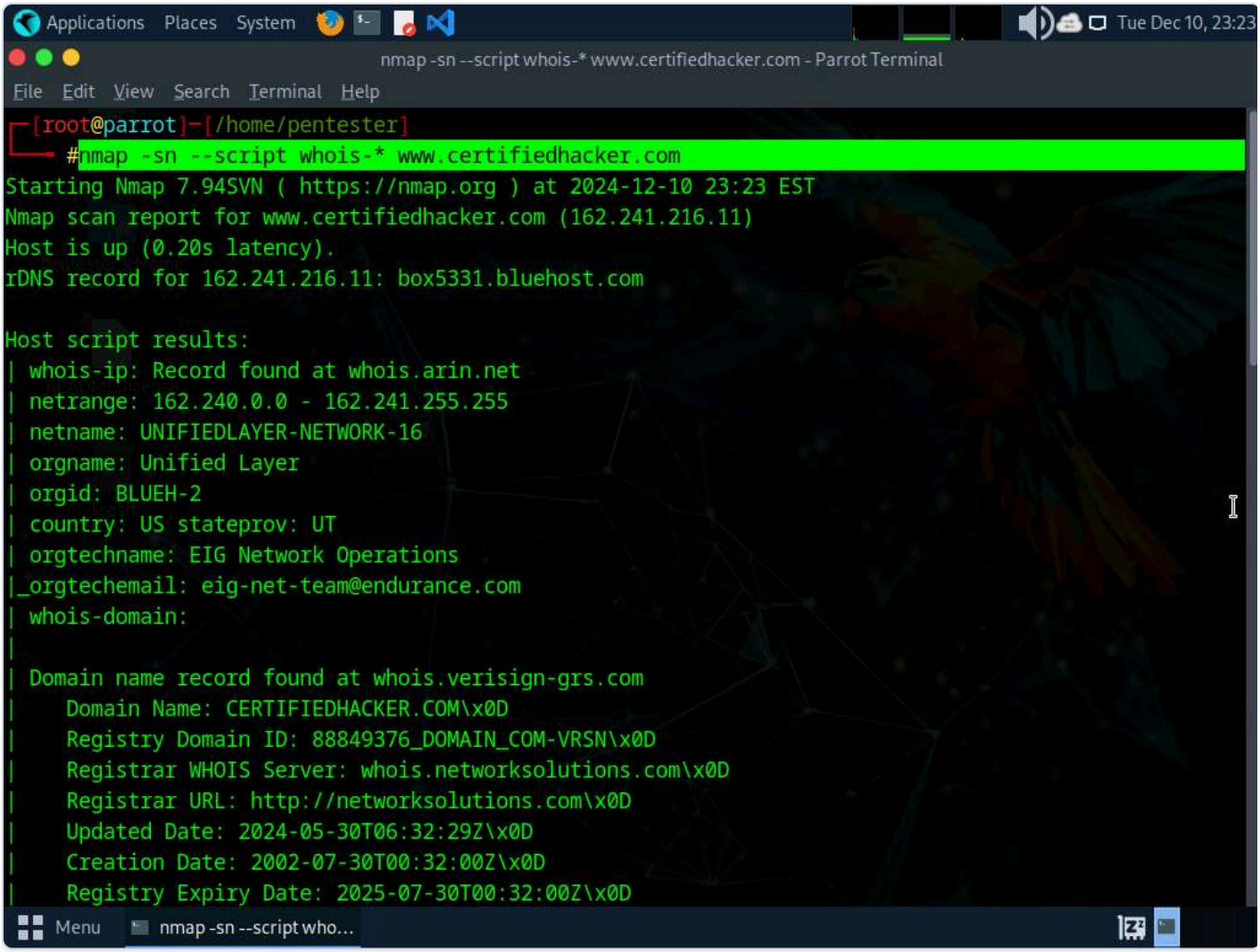
In this lab, we will perform Whois lookup using various tools.

Lab Tasks

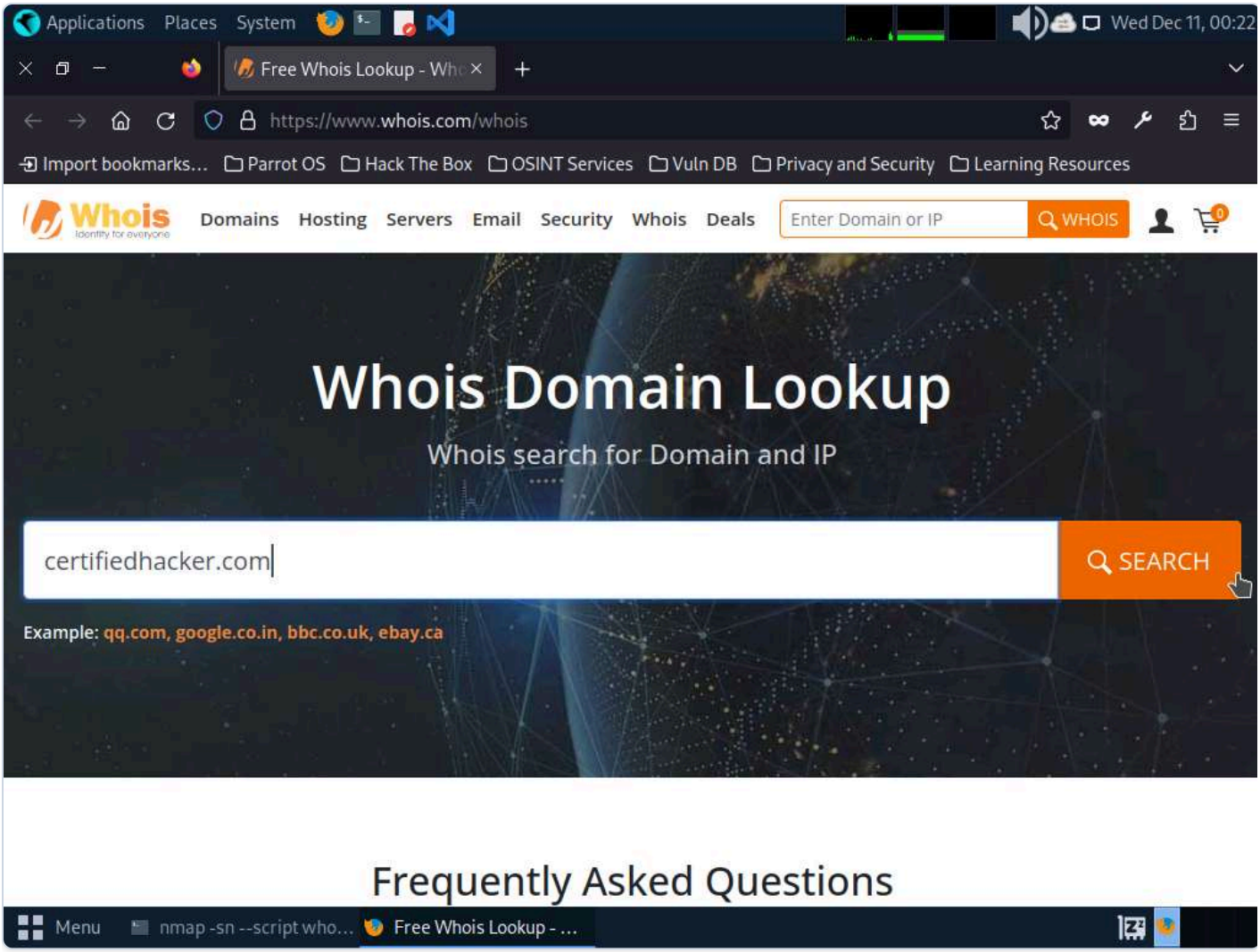
1. Click **Parrot Security** to switch to the Parrot Security machine. Type **toor** in the Password field and press Enter.
2. Launch a terminal and acquire root privileges by executing **sudo su** command. (When prompted for a password, type **toor**).
3. In the terminal window, run **whois certifiedhacker.com** to gather whois information of **www.certifiedhacker.com**.



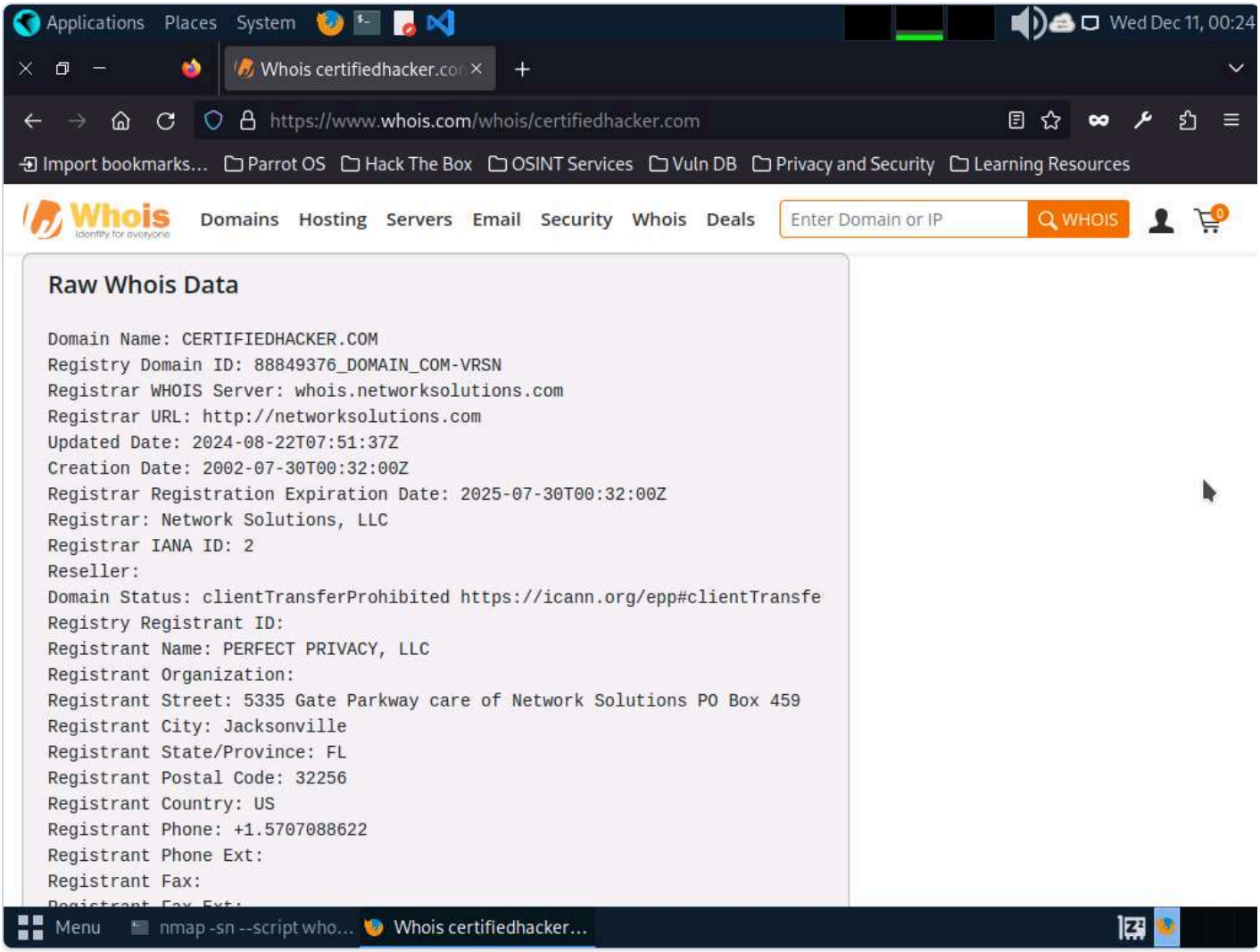
1. Now, we will perform the Whois lookup using Nmap, in the terminal run **nmap -sn --script whois-* www.certifiedhacker.com** command.



1. We will now perform whois lookup using whois.com, open a browser, and in the address bar type **https://www.whois.com/whois/** and press Enter. In the Whois Domain Lookup page search for **certifiedhacker.com**.



1. **whois.com** displays the whois information of the **certifiedhacker.com** website.



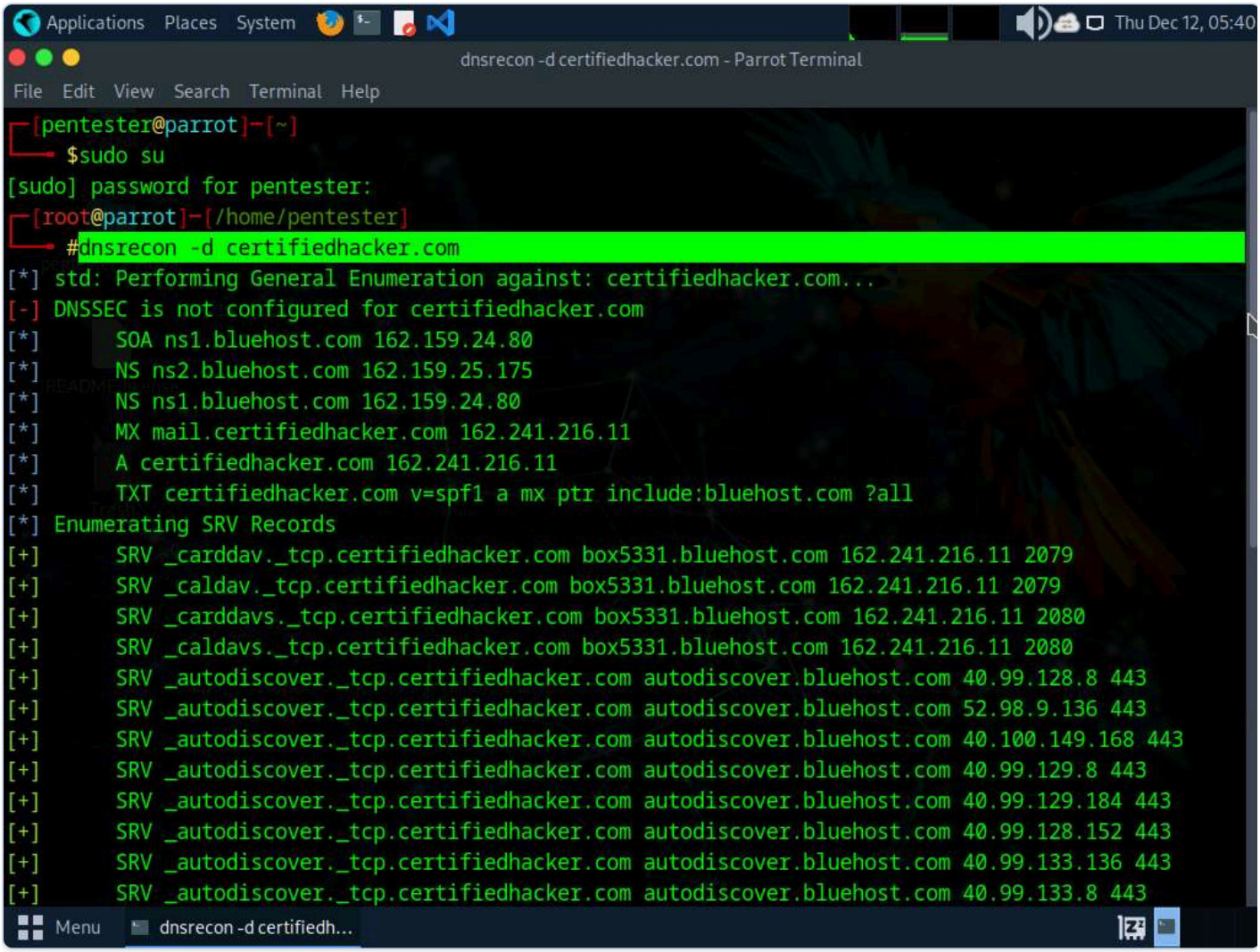
IMPORTANT: ❓ **Question 3.1.1.1** On the Parrot Security machine, utilize the **whois** command, Nmap, and the Whois website (**https://www.whois.com**) to conduct a Whois lookup on **certifiedhacker.com**. Record the rDNS entry for **162.241.216.11**. [!SUCCESS] ✅ **Answer:** **box5331.bluehost.com**

Task 2: Finding DNS Records for the Domain

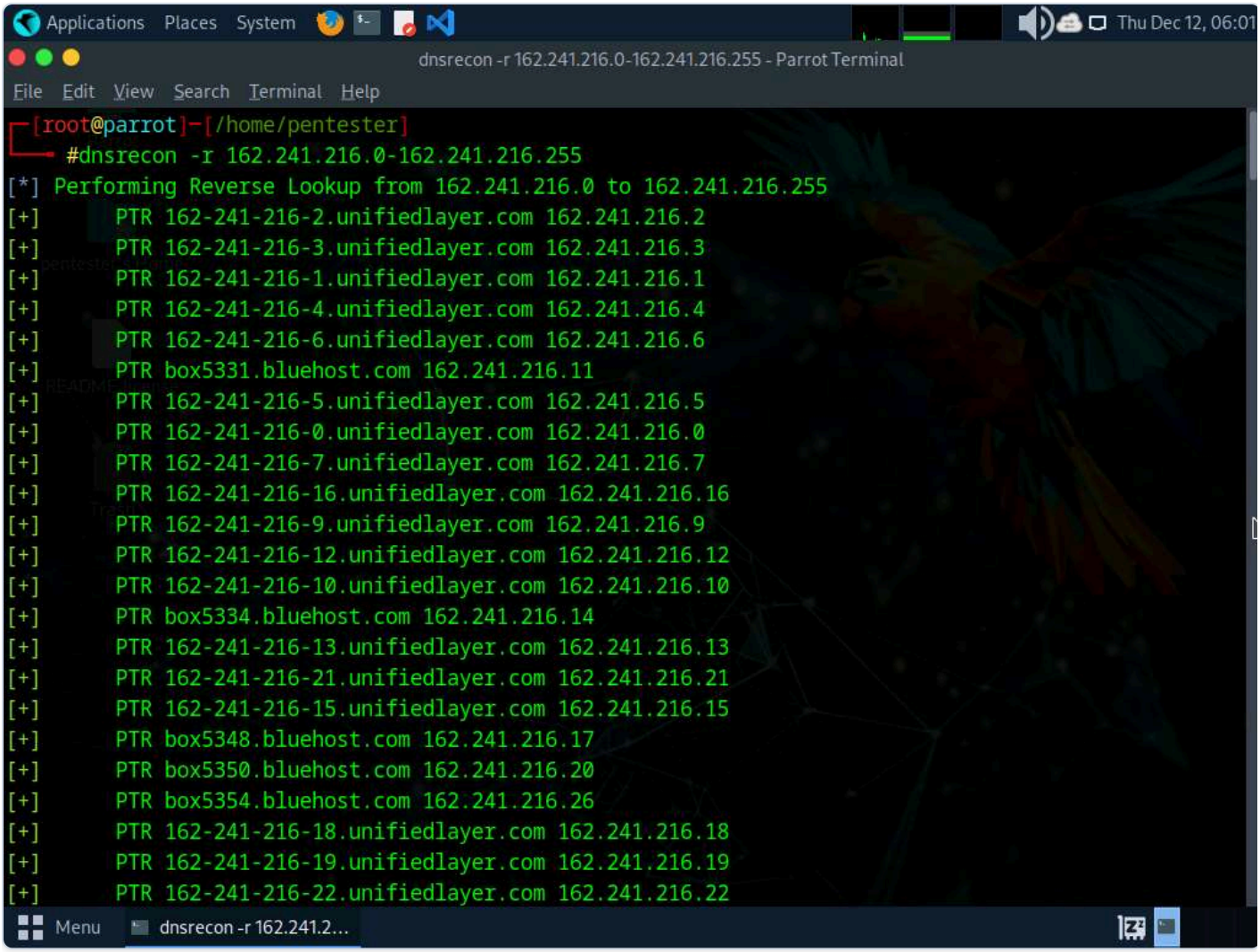
DNS records provide critical information such as domain names, computer names, and IP addresses within a network.

Lab Tasks

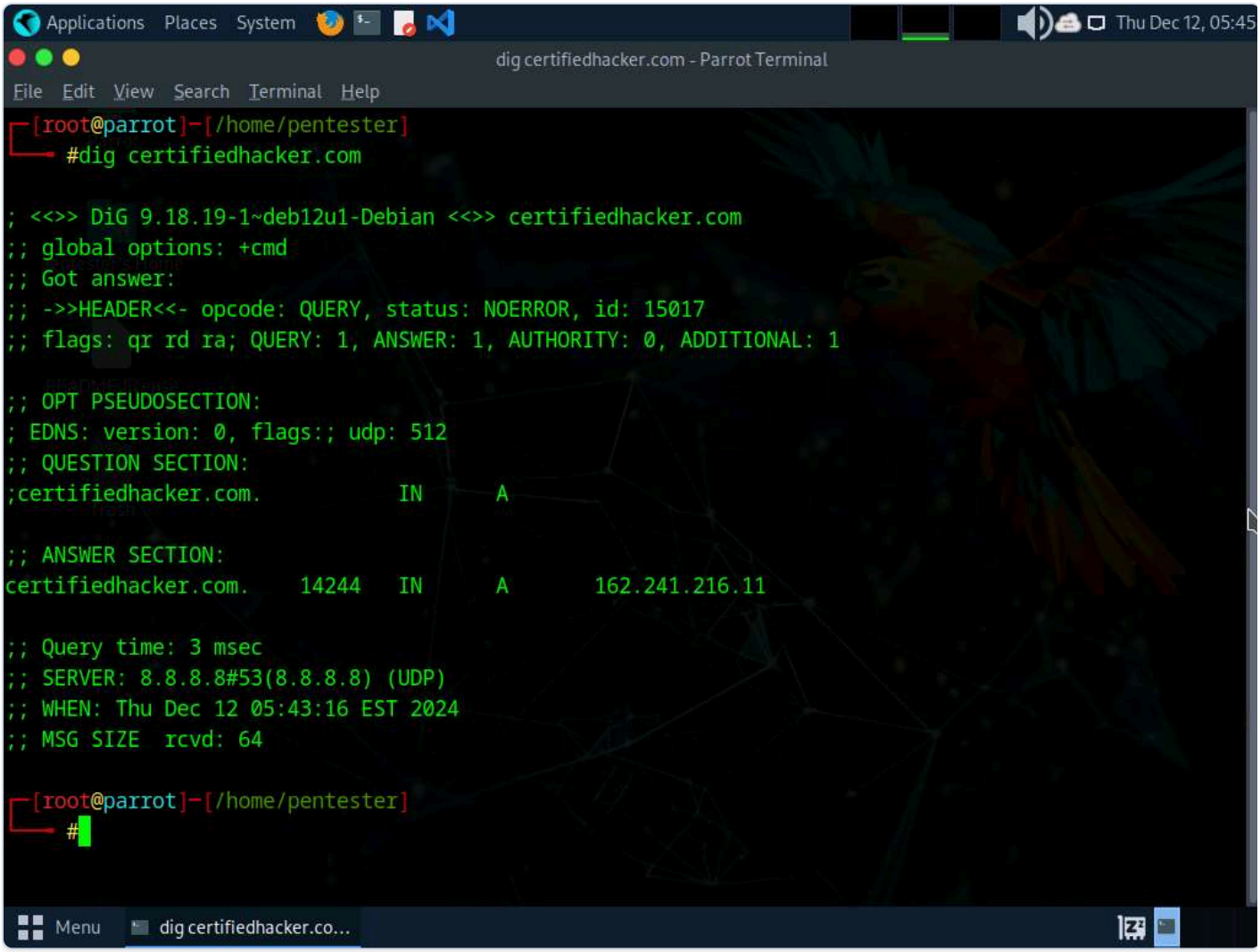
1. In Parrot Security machine, open a new terminal with sudo privileges, and type **dnsrecon -d certifiedhacker.com** to view the DNS records of **certifiedhacker.com**.



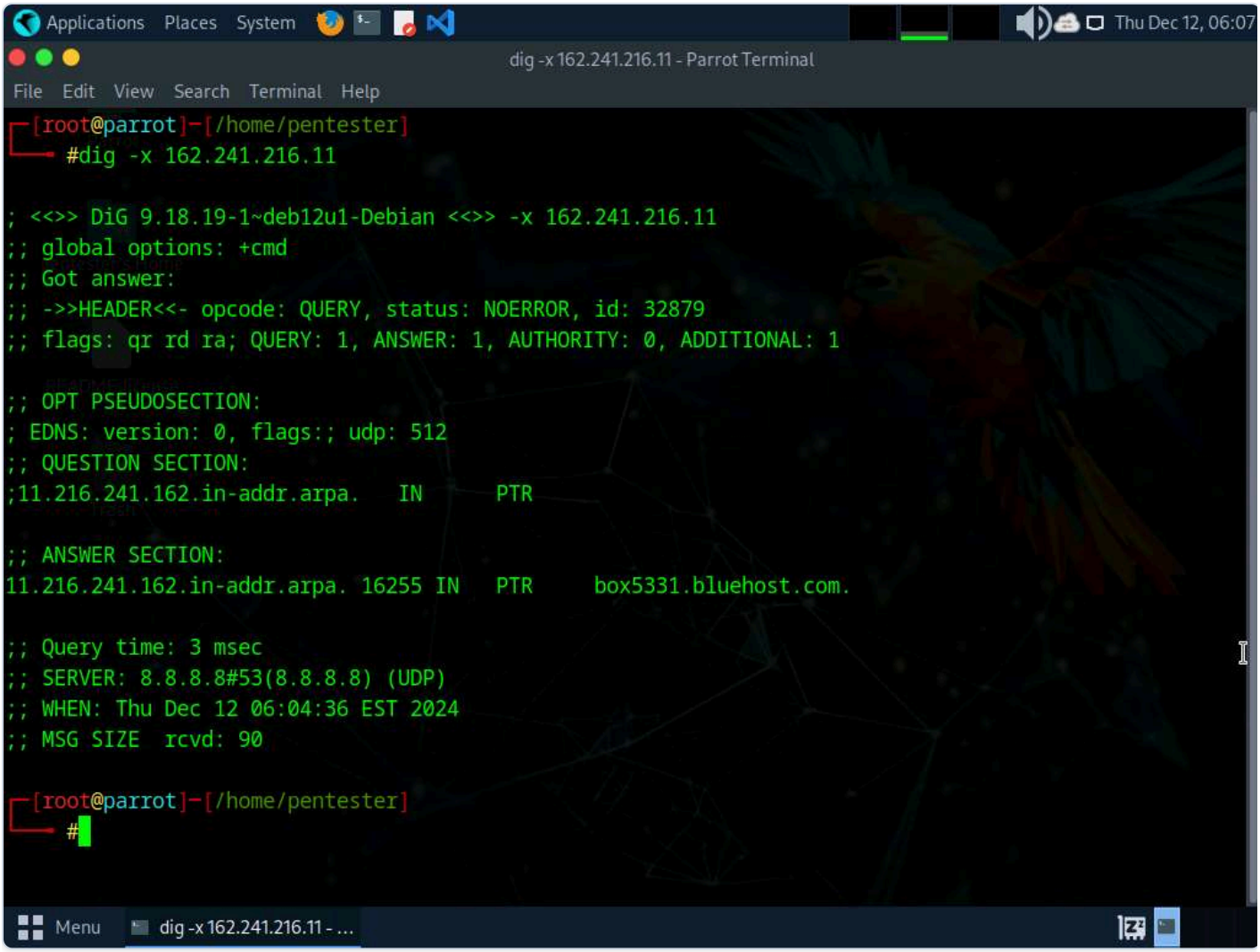
1. To perform reverse lookup run **dnsrecon -r 162.241.216.0-162.241.216.255** command.



1. In the terminal window run the **dig certifiedhacker.com** command to gather the dns information of **certifiedhacker.com**.



1. To perform reverse dns lookup using dig run **dig -x 162.241.216.11** command.



This concludes the demonstration of gathering the dns information from a target domain.

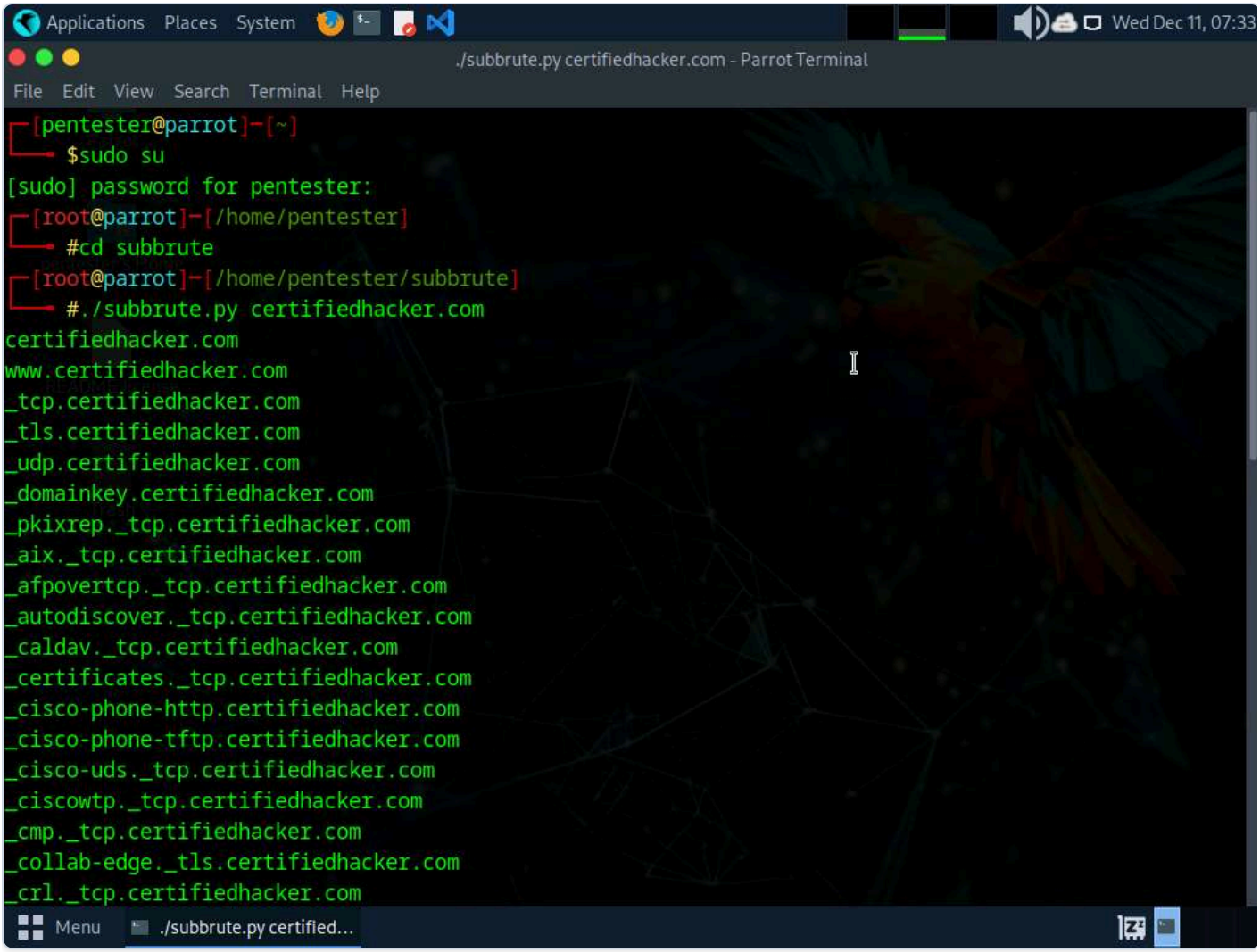
> **IMPORTANT:** ❓ **Question 3.1.2.1** On the Parrot Security machine, use the **dnsrecon** tool to retrieve the DNS records for **certifiedhacker.com**. Identify and enter the IP address of the name server **ns1.bluehost.com**.
> [!SUCCESS] ✅ **Answer:** **162.159.24.80**

Task 3: Finding Domain and Sub-domains of the Target

In this lab, you will learn to identify and analyze the domain and subdomains of a target website using multiple tools and techniques. By leveraging tools like Subbrute, Nmap, Sublist3r, Netcraft, and DNSDumpster, you will gather valuable information for further exploitation and analysis of the target's online presence.

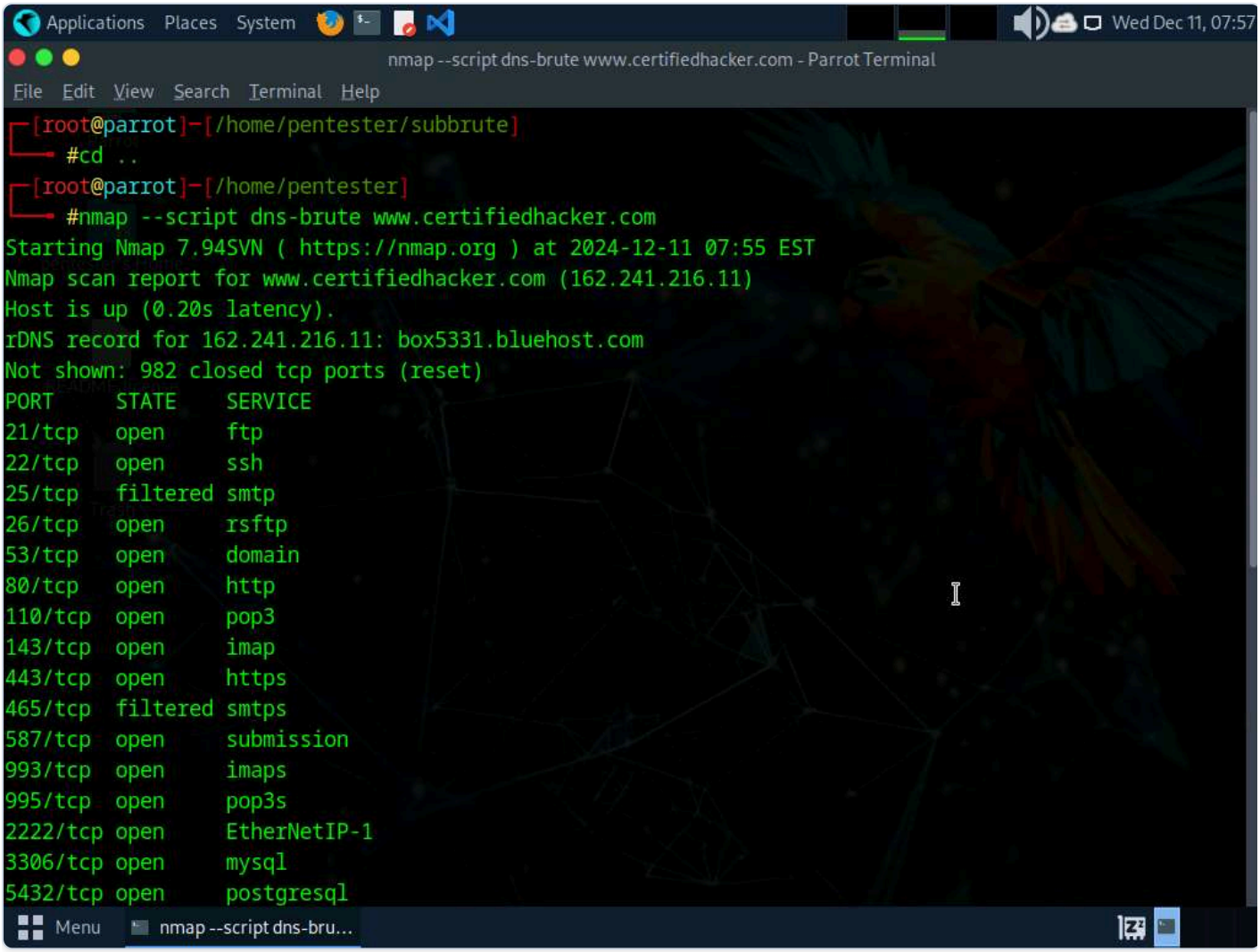
Lab Tasks

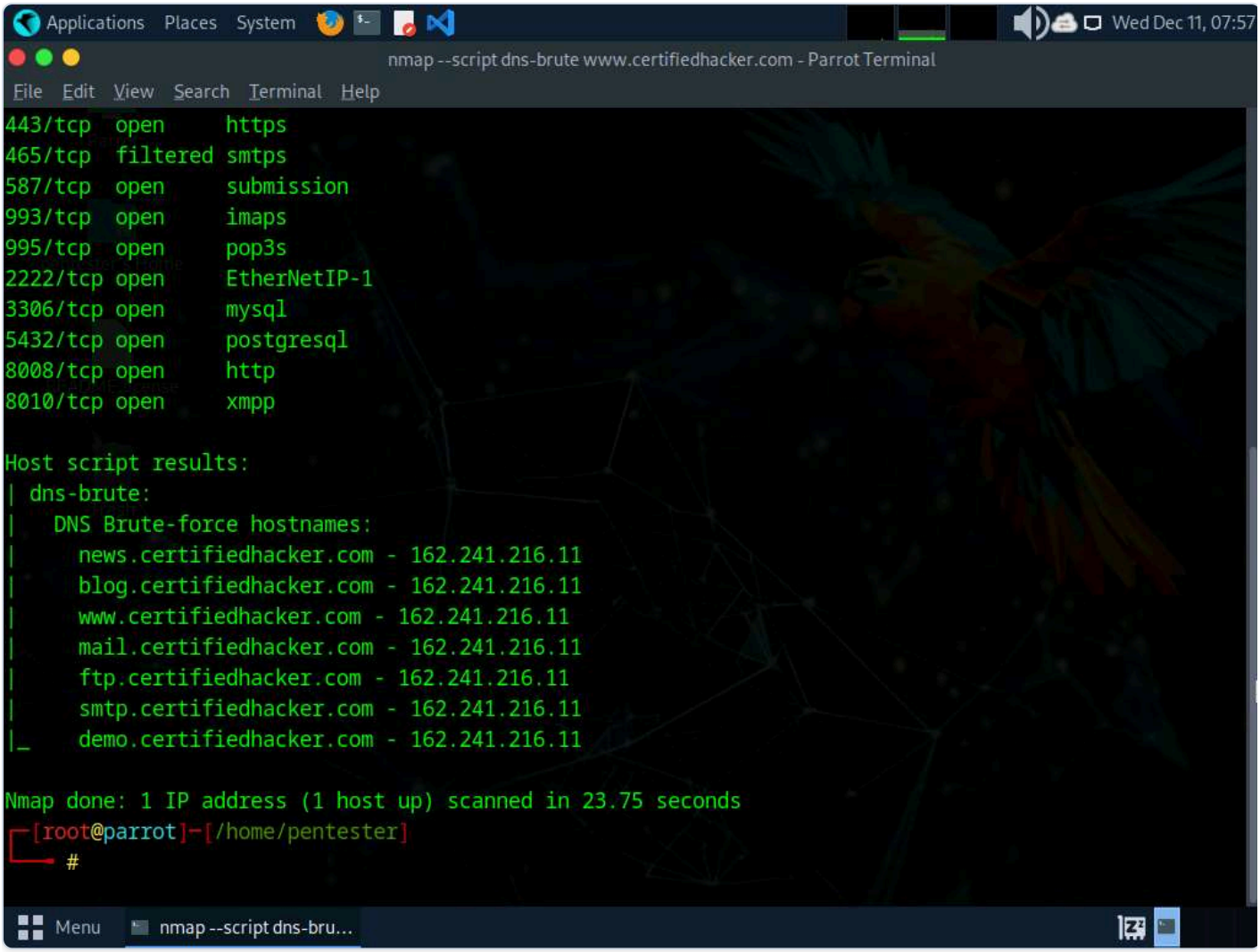
1. In Parrot Security machine, open a new terminal with sudo privileges, and type **cd subbrute** to navigate to the subbrute directory.
2. In the subbrute directory run **./subbrute.py certifiedhacker.com** command. It will take some time for the output to appear.
3. If the command is taking too long, try running **python3 subbrute.py certifiedhacker.com** or include **www.certifiedhacker.com** in the command.



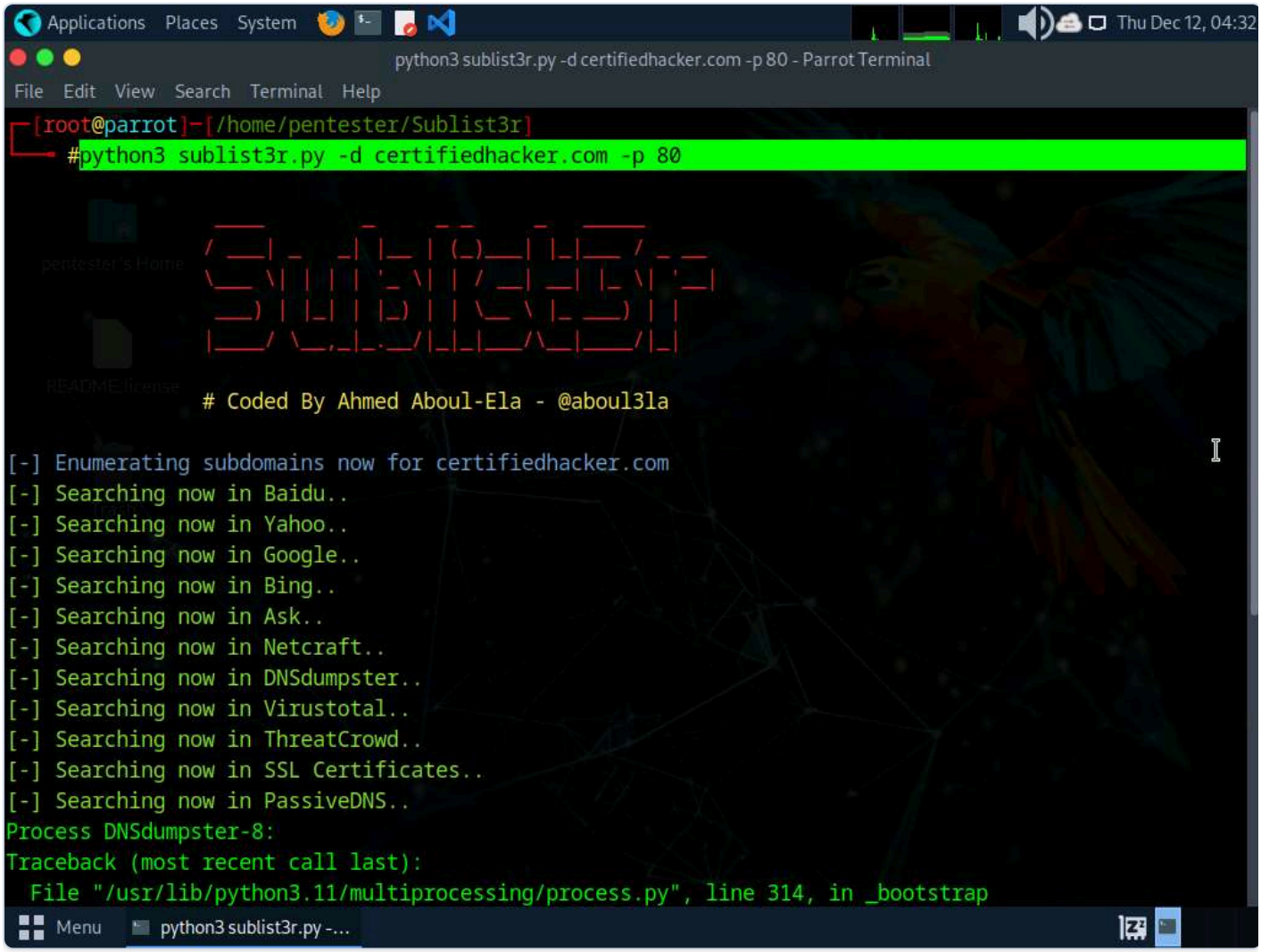
The sub-domains of **www.certifiedhacker.com** will be listed, which can be used for further exploitation of the target.

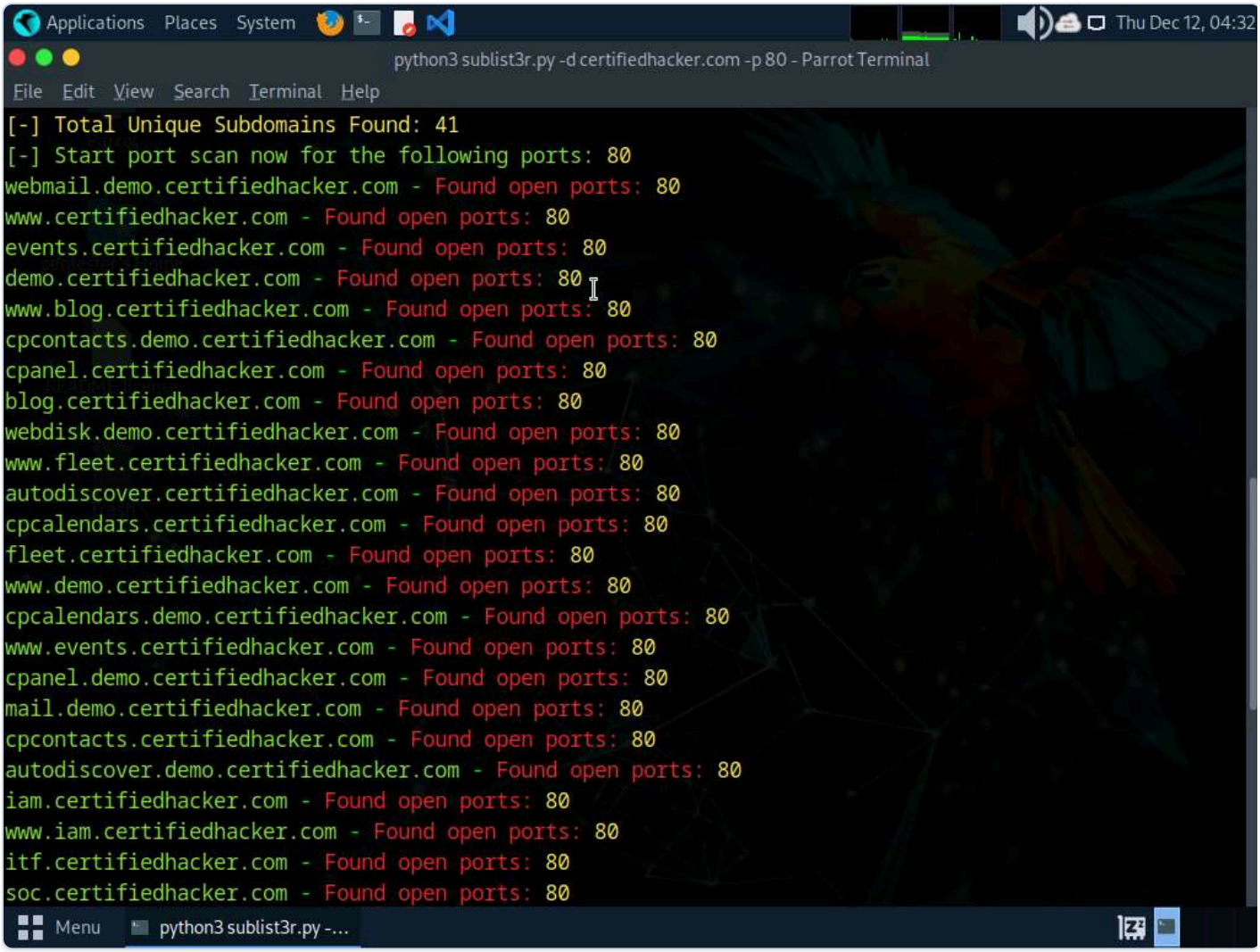
1. Now, we will use nmap to scan for a list of sub-domains in the **www.certifiedhacker.com** domain. In the terminal run **cd ..** to navigate to **/home/pentester**.
2. Run **nmap --script dns-brute www.certifiedhacker.com** command to view the sub-domains of **www.certifiedhacker.com**.


Applications Places System
Wed Dec 11, 07:57
nmap --script dns-brute www.certifiedhacker.com - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]-[/home/pentester/subbrute]
#cd ..
[root@parrot]-[/home/pentester]
#nmap --script dns-brute www.certifiedhacker.com
Starting Nmap 7.94SVN (https://nmap.org) at 2024-12-11 07:55 EST
Nmap scan report for www.certifiedhacker.com (162.241.216.11)
Host is up (0.20s latency).
rDNS record for 162.241.216.11: box5331.bluehost.com
Not shown: 982 closed tcp ports (reset)
PORT STATE SERVICE
21/tcp open ftp
22/tcp open ssh
25/tcp filtered smtp
26/tcp open rsftp
53/tcp open domain
80/tcp open http
110/tcp open pop3
143/tcp open imap
443/tcp open https
465/tcp filtered smtps
587/tcp open submission
993/tcp open imaps
995/tcp open pop3s
2222/tcp open EtherNetIP-1
3306/tcp open mysql
5432/tcp open postgresql
Menu
nmap --script dns-bru...

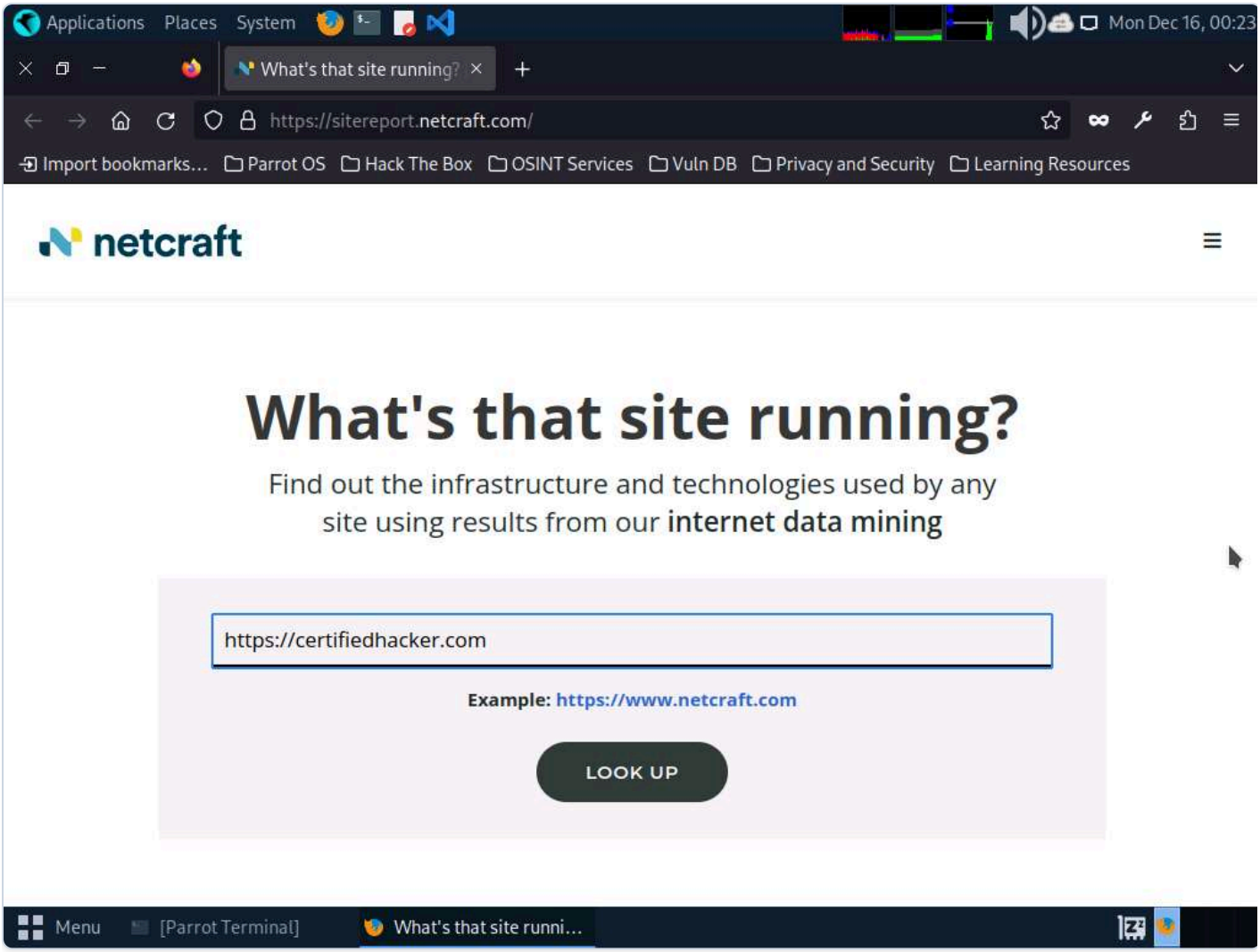


1. We will now scan for sub-domains using the sublist3r tool, in the terminal window, type **cd Sublist3r** to navigate to the sublist3r directory.
2. Run **python3 sublist3r.py -d certifiedhacker.com -p 80** command to view the list of sub-domains.
3. If you receive any errors while running the command ignore them.

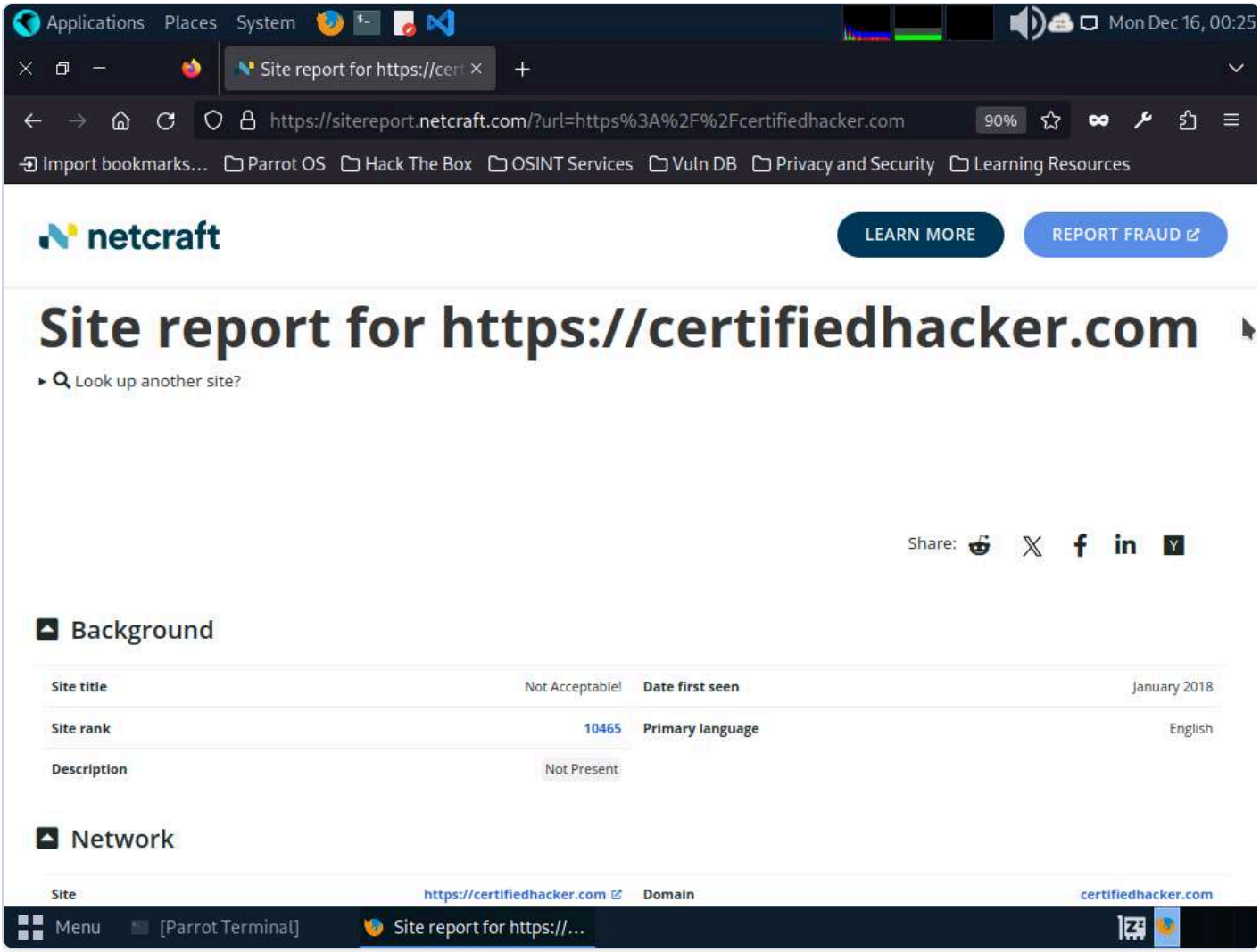

Applications Places System
Thu Dec 12, 04:32
python3 sublist3r.py -d certifiedhacker.com -p 80 - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]-[/home/pentester/Sublist3r]
#python3 sublist3r.py -d certifiedhacker.com -p 80
Coded By Ahmed Aboul-Ela - @aboul3la
[-] Enumerating subdomains now for certifiedhacker.com
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
Process DNSdumpster-8:
Traceback (most recent call last):
File "/usr/lib/python3.11/multiprocessing/process.py", line 314, in _bootstrap
Menu
python3 sublist3r.py -...

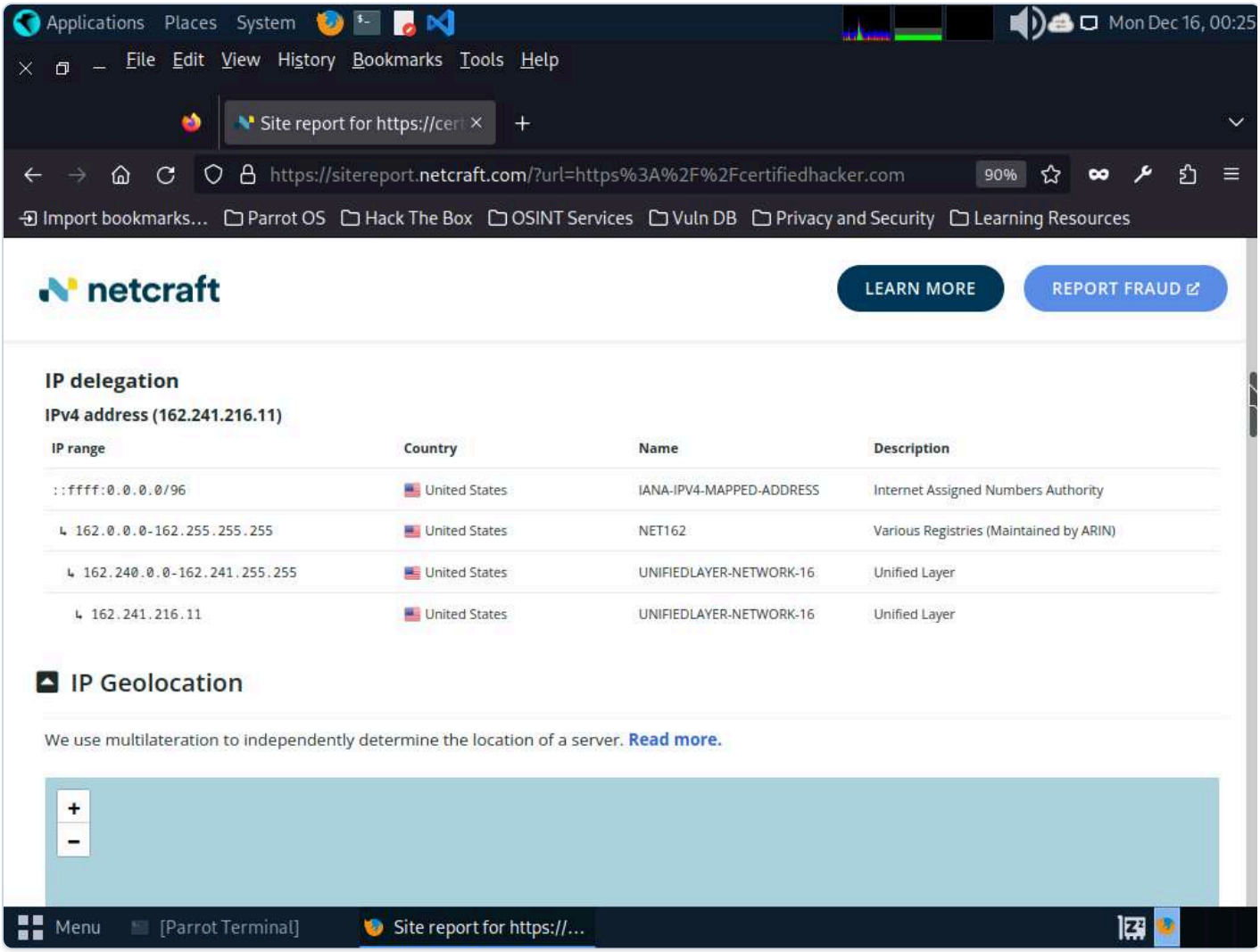


1. We will now list the sub-domains of the **www.certifiedhacker.com** website using Netcraft.
2. Open a browser and in the address bar type **https://sitereport.netcraft.com/** and press Enter.
3. If a pop-up appears, click on **ACCEPT COOKIES**.
4. In the netcraft web page, under **What's that site running?** section type **https://certifiedhacker.com** and click **LOOK UP**.

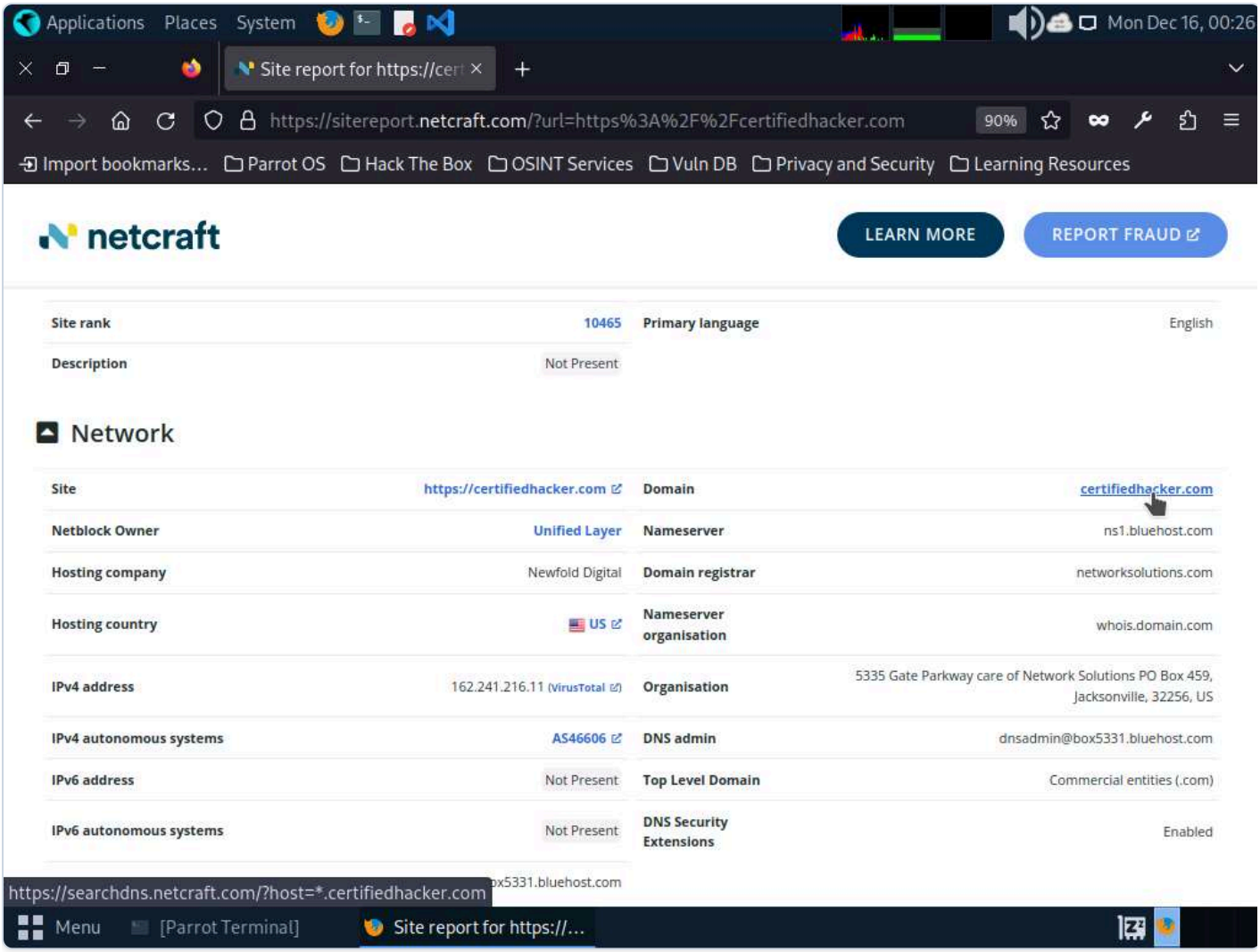


1. **Site report for https://certifiedhacker.com** page appears, displaying the Background, Network, IP delegation, IP Geolocation etc.

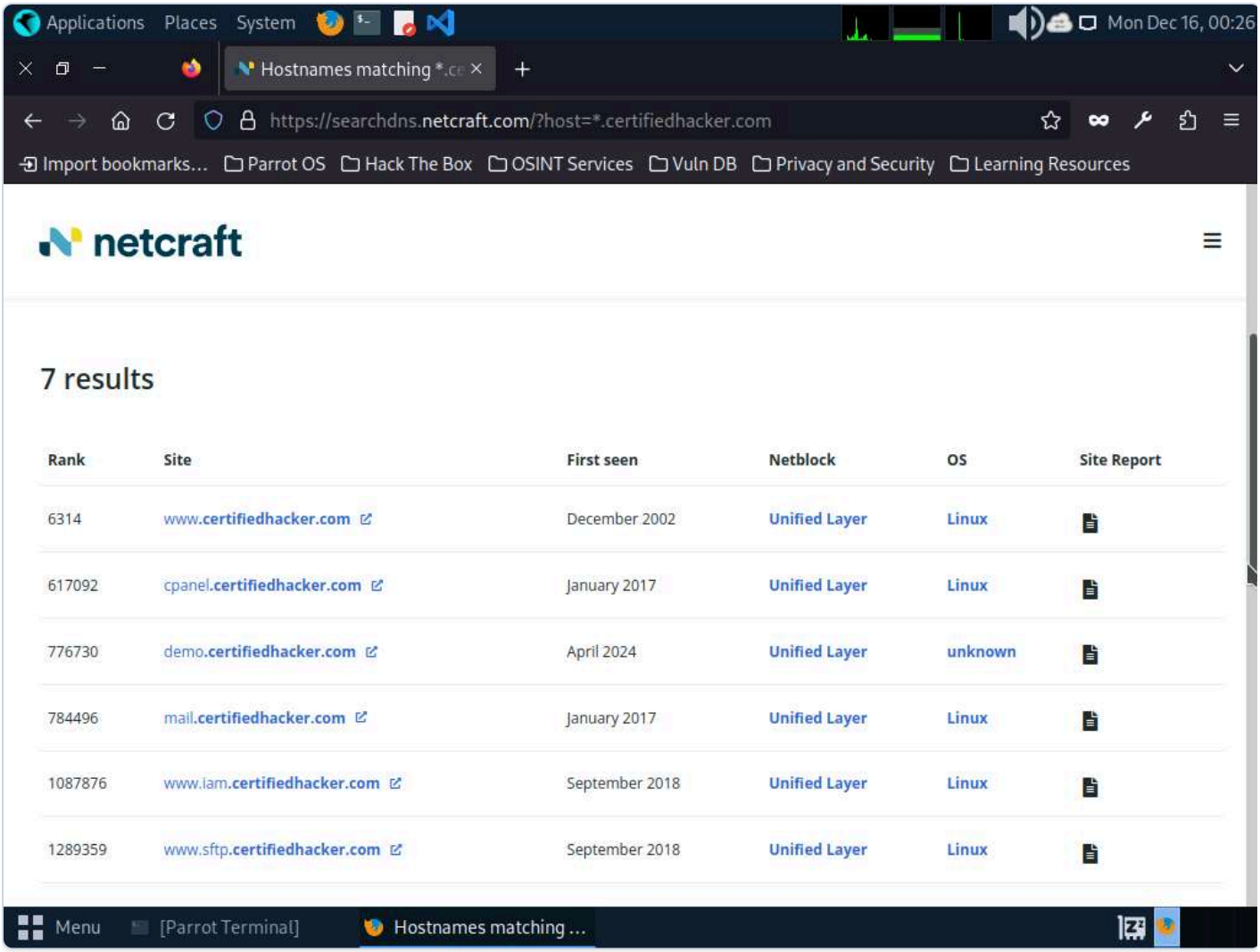

Applications Places System
Mon Dec 16, 00:25
Site report for https://cert
https://sitereport.netcraft.com/?url=https%3A%2F%2Fcertifiedhacker.com
90%
Import bookmarks... Parrot OS Hack The Box OSINT Services Vuln DB Privacy and Security Learning Resources
netcraft
LEARN MORE
REPORT FRAUD
Site report for https://certifiedhacker.com
Look up another site?
Share:
Background
Site title
Not Acceptable!
Date first seen
January 2018
Site rank
10465
Primary language
English
Description
Not Present
Network
Site
https://certifiedhacker.com
Domain
certifiedhacker.com
Menu
[Parrot Terminal]
Site report for https://...



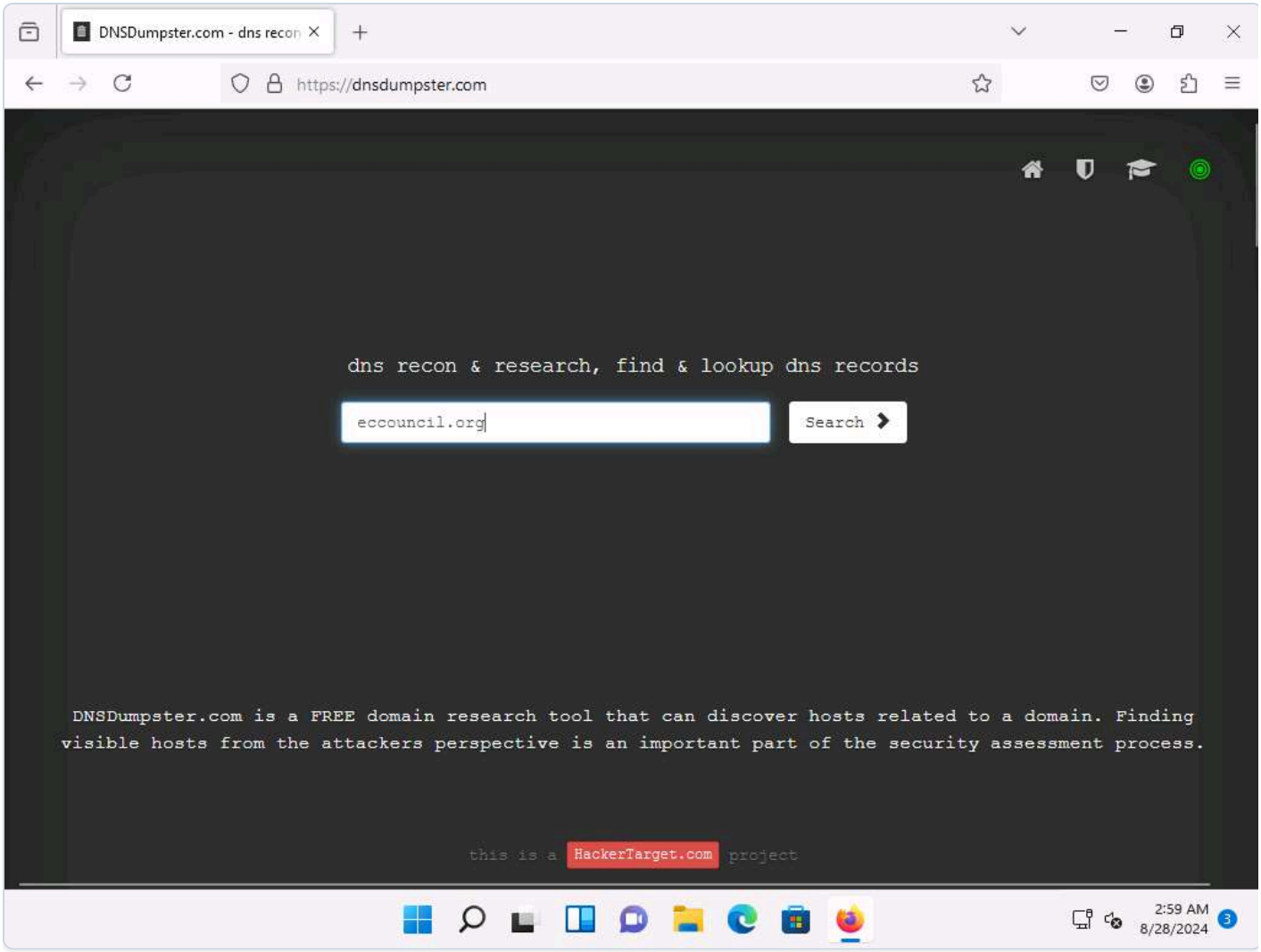
1. Analyze the information and click on **certifiedhacker.com** hyperlink beside Domain under Network section.

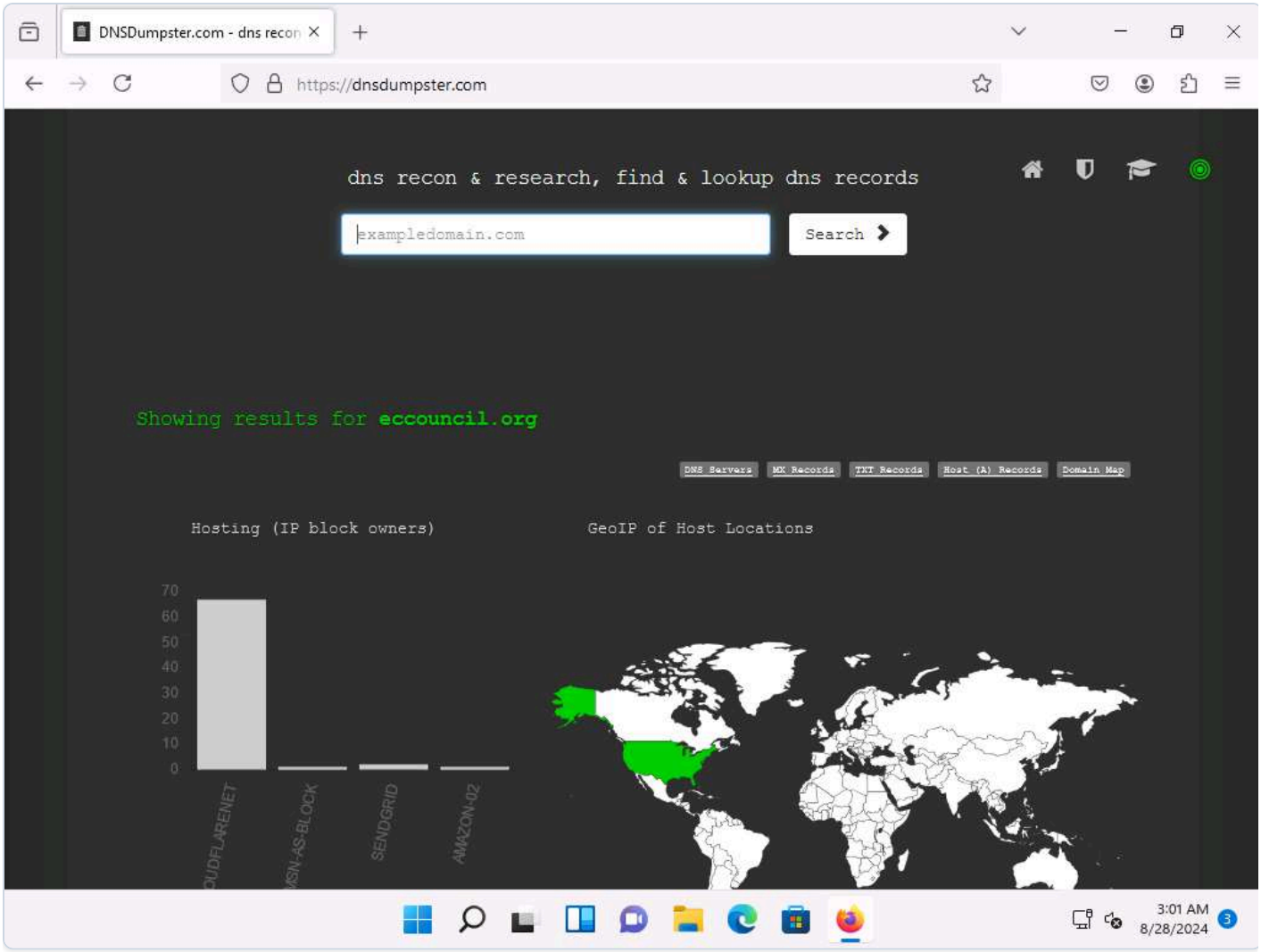


1. This will list all the sub-domains of the **certifiedhacker.com** website.

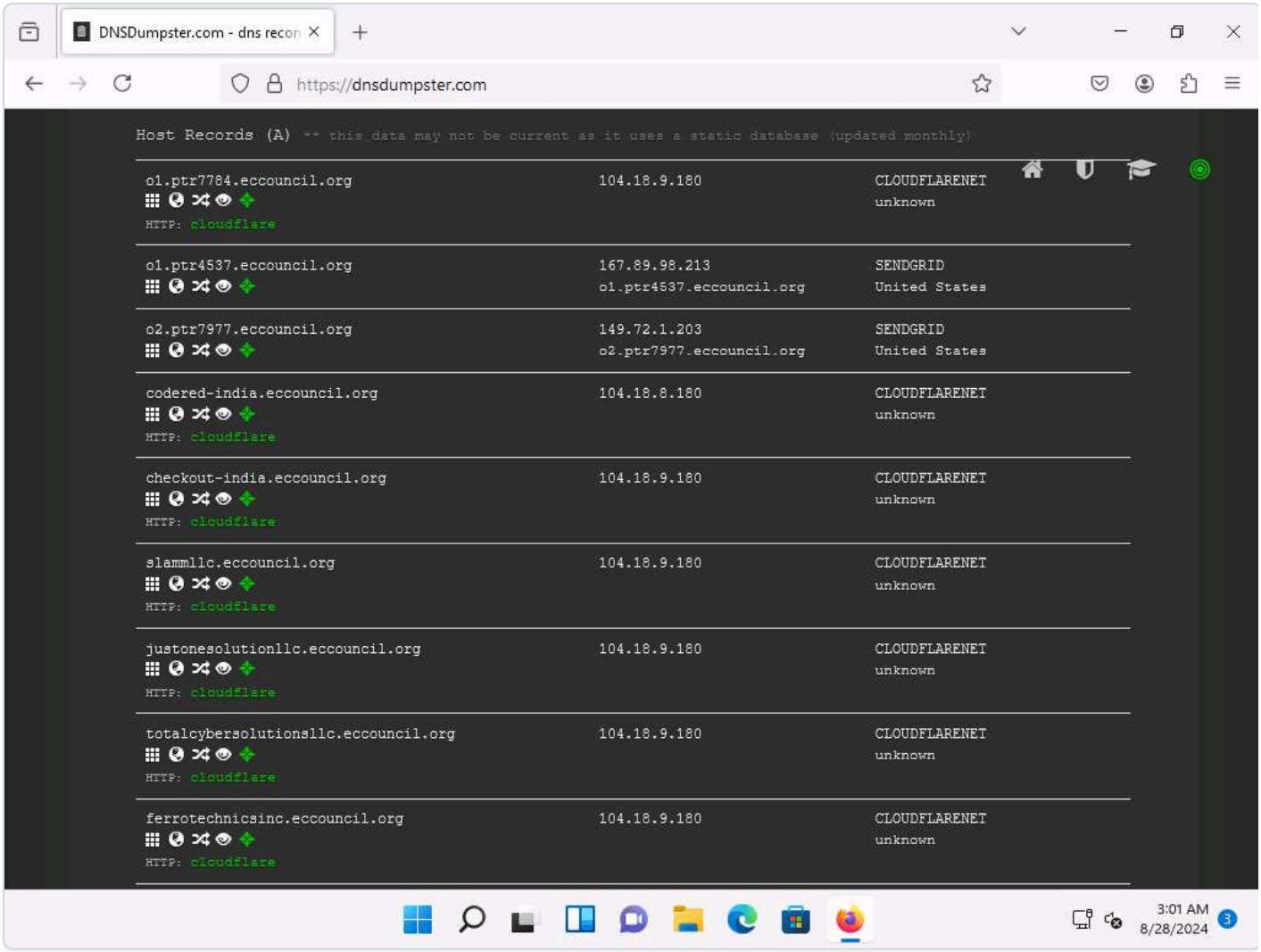


1. Next, we will perform DNS Recon & Research using **https://dnsdumpster.com**.
2. In your browser enter **https://dnsdumpster.com** and enter **eccouncil.org**.


DNSDumpster.com - dns recon
https://dnsdumpster.com
dns recon & research, find & lookup dns records
eccouncil.org
Search
DNSDumpster.com is a FREE domain research tool that can discover hosts related to a domain. Finding visible hosts from the attackers perspective is an important part of the security assessment process.
this is a HackerTarget.com project
2:59 AM
8/28/2024



1. Scroll down and look at the host section.



Take a few minutes and explore the data results. We have accomplished what we wanted to in this lab and will conclude the lab here.

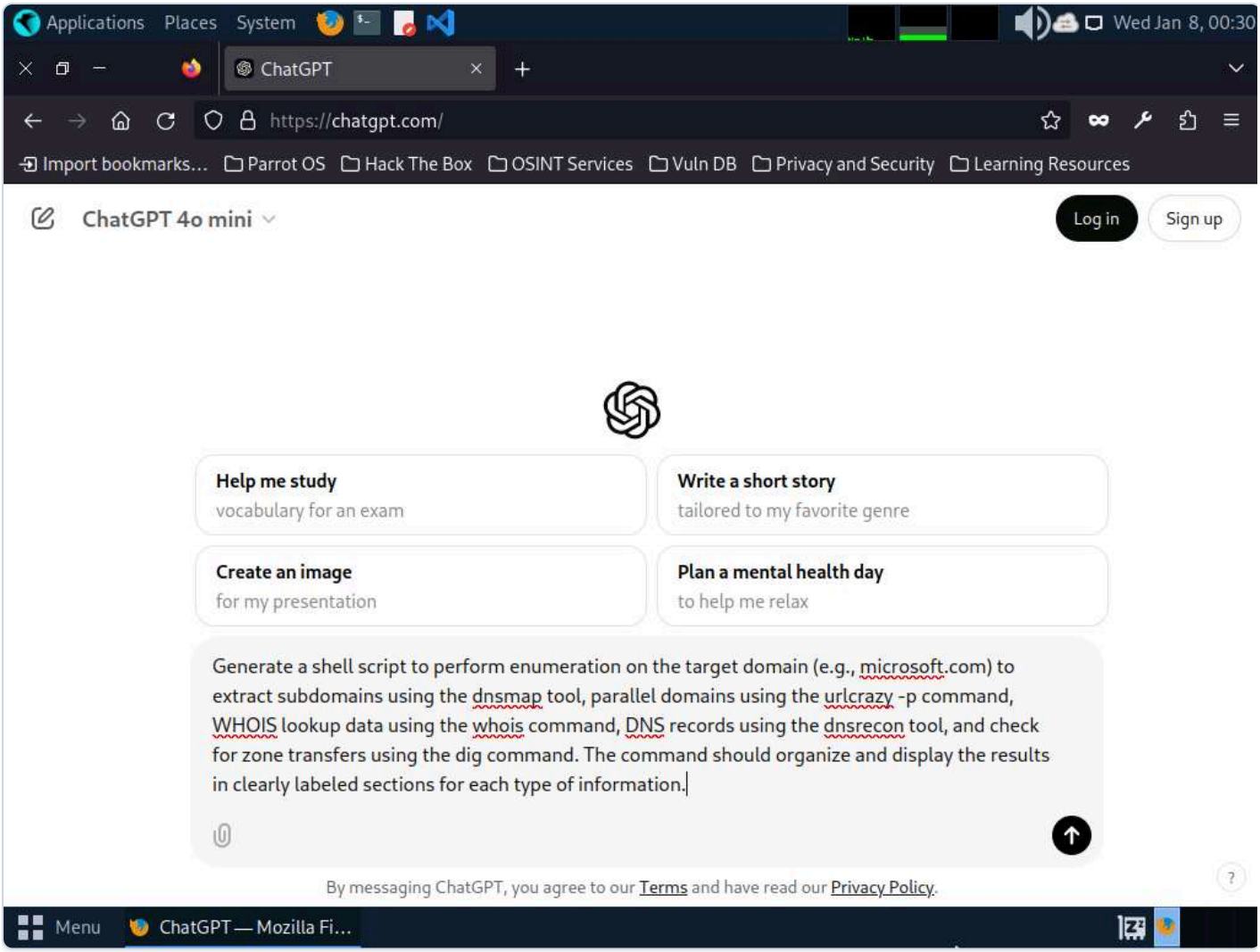
> **IMPORTANT:** ❓ **Question 3.1.3.1** On the Parrot Security machine, utilize **subbrute.py**, Nmap, **sublist3r.py**, Netcraft Site Report (**https://sitereport.netcraft.com**), and DNSDumpster (**https://dnsdumpster.com**) to identify the domain and subdomains of **certifiedhacker.com**. Record the total number of hostnames discovered after performing DNS brute-forcing with Nmap. [!SUCCESS] ✅ **Answer:** **37**

Task 4: Using Scripts and AI Tools to Combine and Automate OSINT

In this lab, you will use an AI tool to generate a script for automating OSINT tasks on a target domain. The script will extract subdomains, parallel domains, WHOIS data, and DNS records, and check for zone transfers, providing organized results in labeled sections and saving them to a text file.

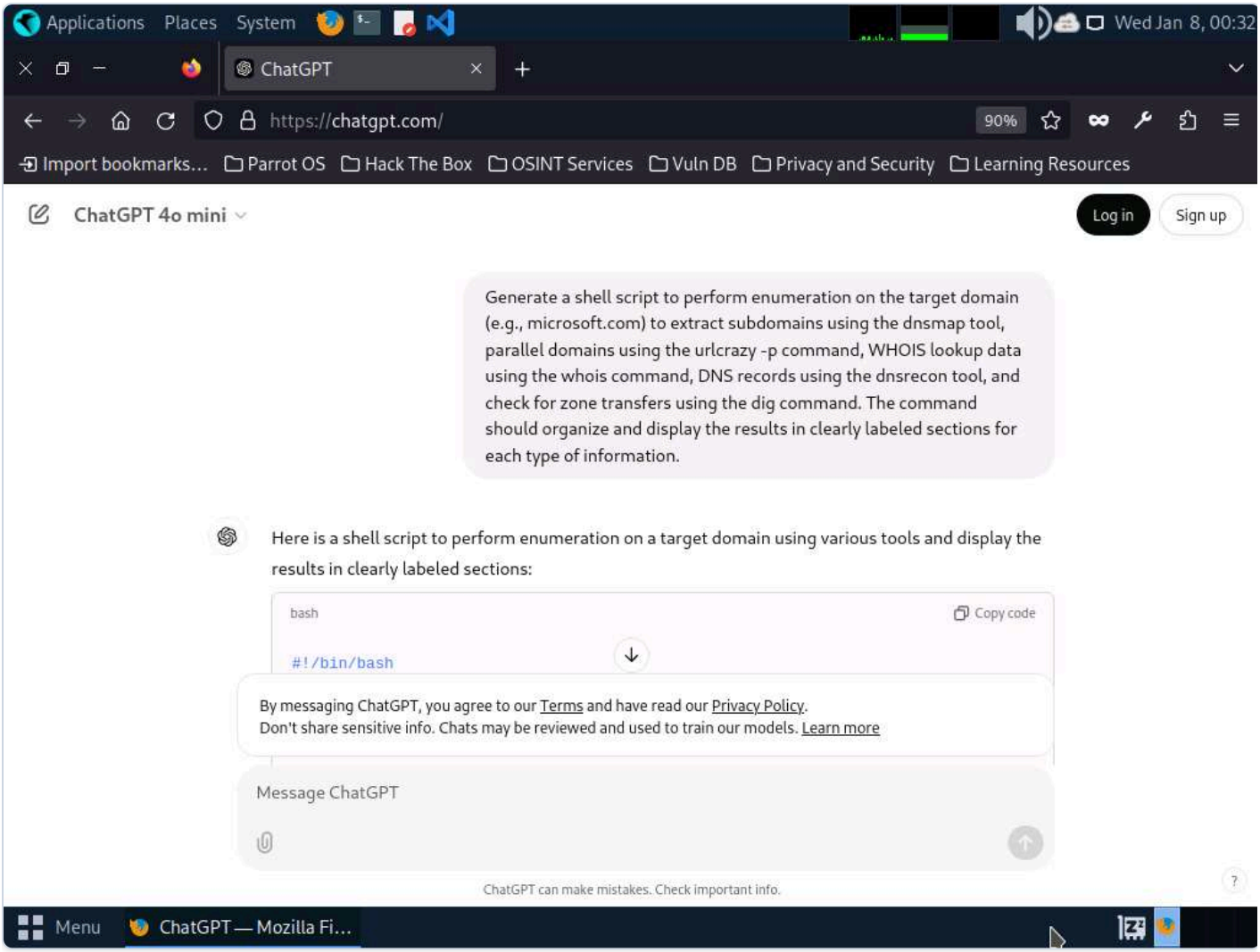
Lab Tasks

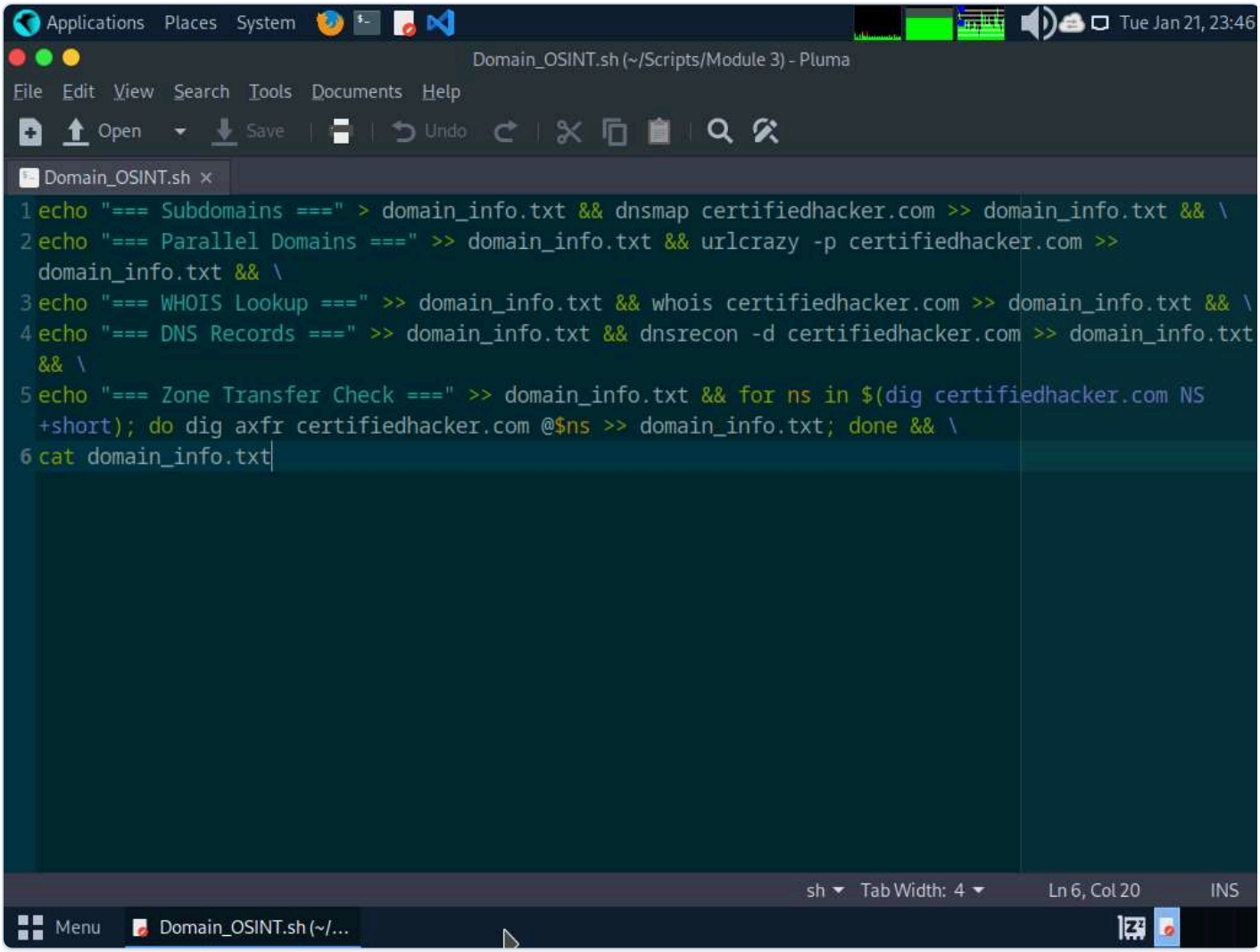
1. Click **Parrot Security** to switch to the Parrot Security machine, open the browser, and go to any AI tool, here we are using **ChatGPT** (**https://chatgpt.com/**).
2. If *Allow chatgpt.com to store data in persistent storage?* pop-up appears, click **Allow**.
3. If a *Log in to unlock GPT-5* pop-up appears, close it.



1. Enter the following sample prompt to generate a script with commands for combining and automating OSINT tasks:

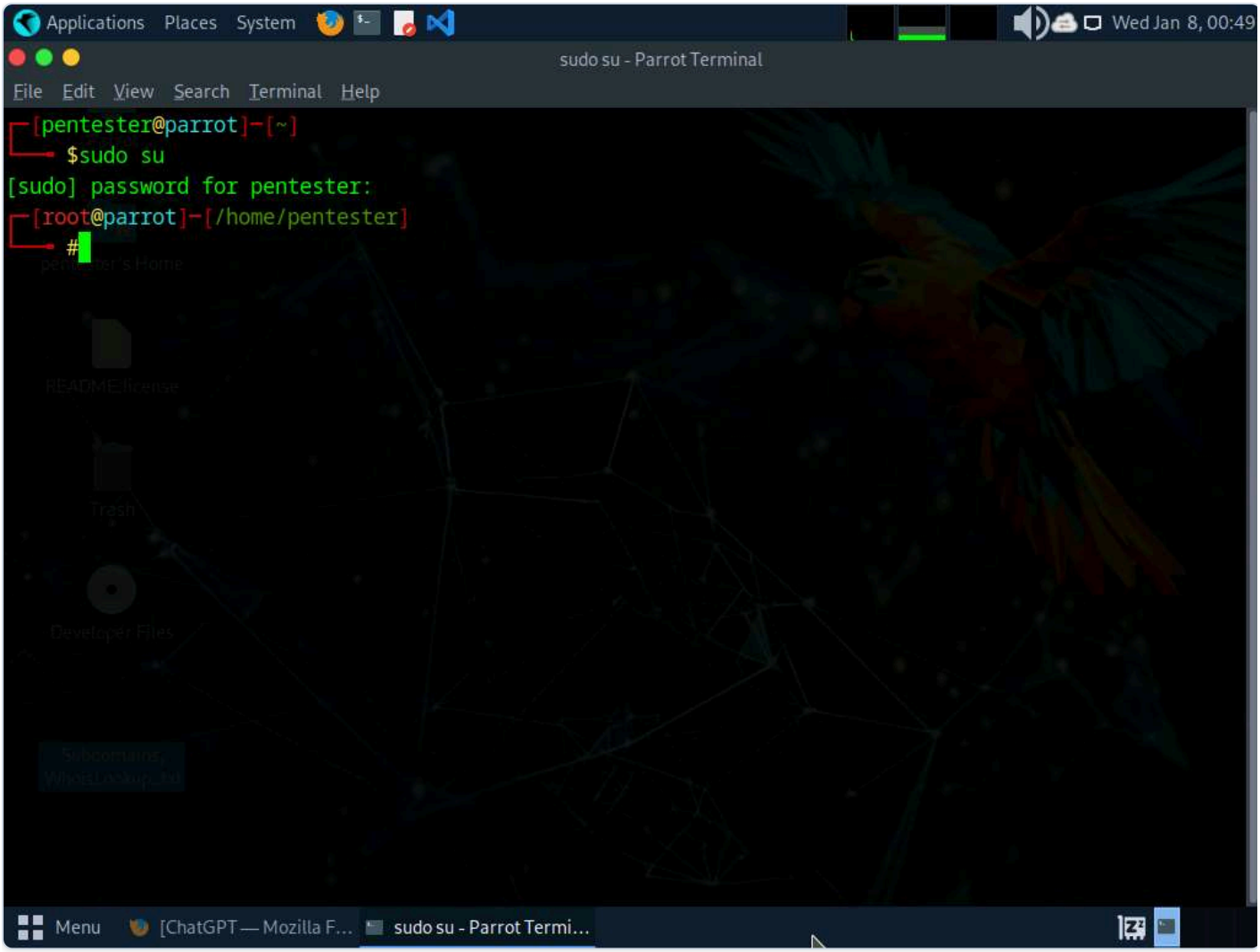
> *"Generate a shell script to perform enumeration on the target domain (e.g., microsoft.com) to extract subdomains using the dnsmap tool, parallel domains using the urlcrazy -p command, WHOIS lookup data using the whois command, DNS records using the dnsrecon tool, and check for zone transfers using the dig command. The command should organize and display the results in clearly labeled sections for each type of information."*


Applications Places System
Wed Jan 8, 00:32
ChatGPT
https://chatgpt.com/
90%
Import bookmarks...
Parrot OS
Hack The Box
OSINT Services
Vuln DB
Privacy and Security
Learning Resources
ChatGPT 4o mini
Log in
Sign up
Generate a shell script to perform enumeration on the target domain (e.g., microsoft.com) to extract subdomains using the dnsmap tool, parallel domains using the urlcrazy -p command, WHOIS lookup data using the whois command, DNS records using the dnsrecon tool, and check for zone transfers using the dig command. The command should organize and display the results in clearly labeled sections for each type of information.
Here is a shell script to perform enumeration on a target domain using various tools and display the results in clearly labeled sections:
bash
Copy code
#!/bin/bash
By messaging ChatGPT, you agree to our Terms and have read our Privacy Policy.
Don't share sensitive info. Chats may be reviewed and used to train our models. Learn more
Message ChatGPT
ChatGPT can make mistakes. Check important info.
Menu
ChatGPT — Mozilla Fi...

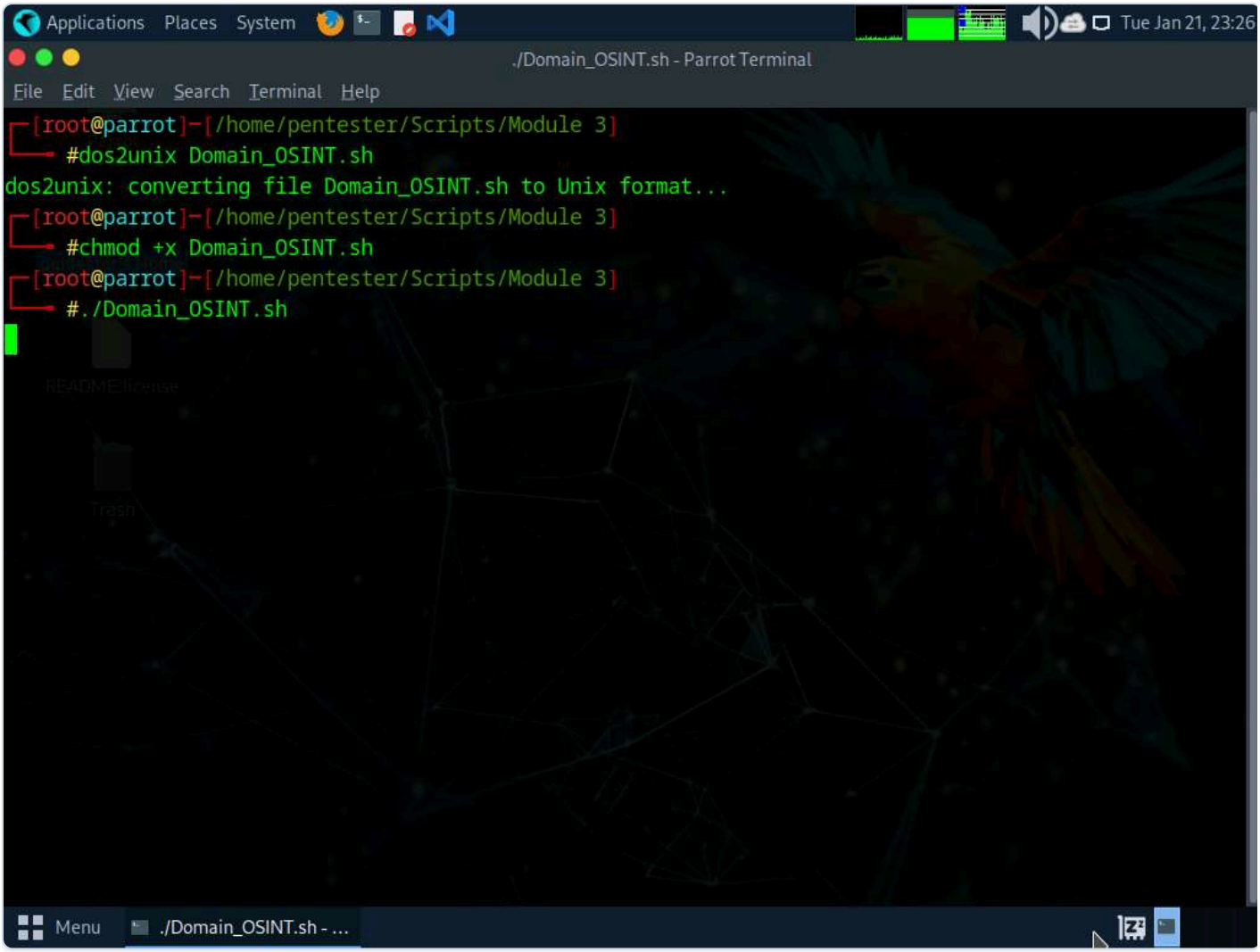


(The output may vary slightly each time you use this prompt.)

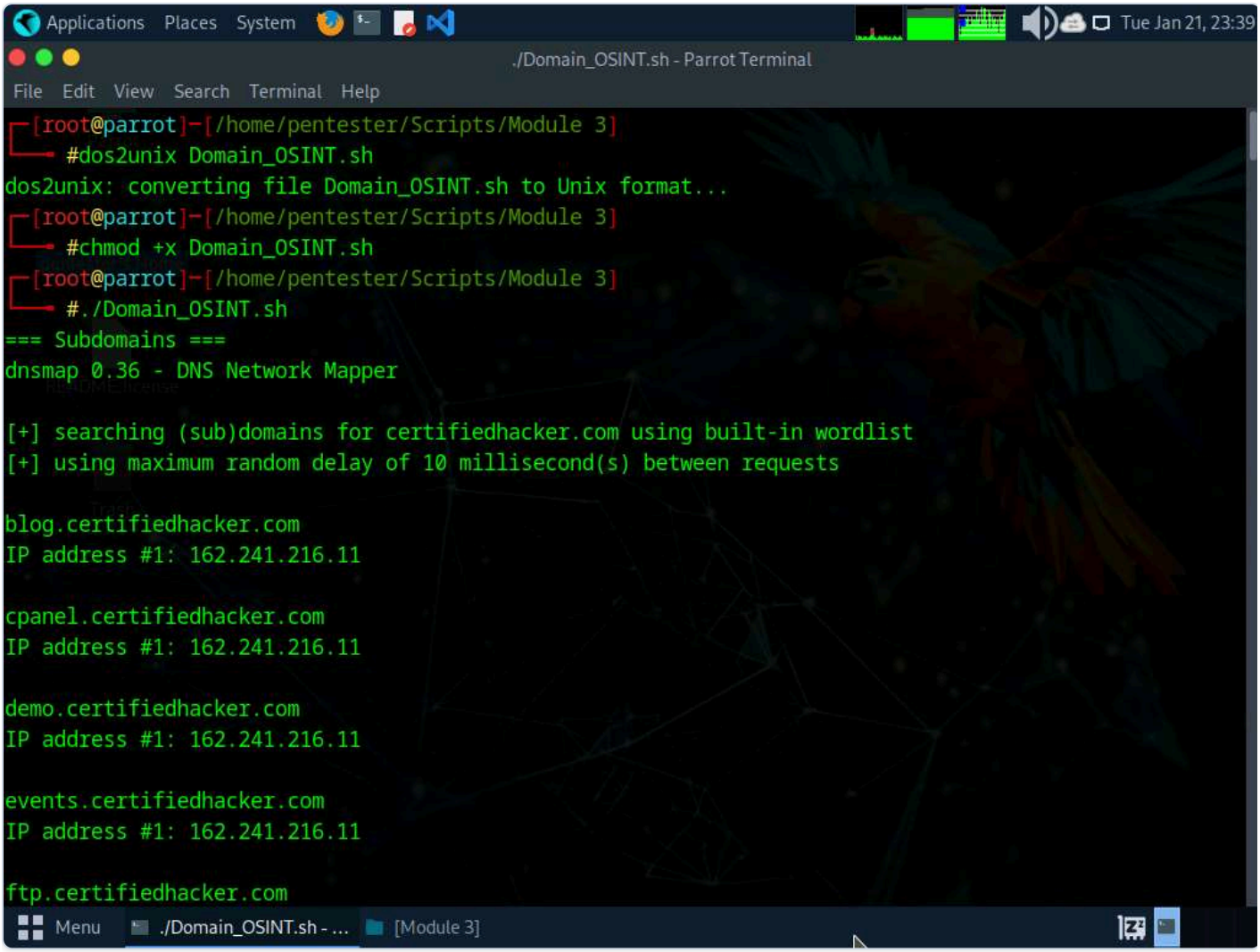
1. Save the generated script in a file named **Domain_OSINT.sh**. (You can use the **Domain_OSINT.sh** file located in **CPENTv2 Pen Testing Resources/CPENTv2 Scripts/Module 03 Open Source Intelligence (OSINT) and Attack Surface Mapping/**).



1. You can run the sample Shell script that is already saved and available as **Domain_OSINT.sh** in the **CPENTv2 Pen Testing Resources/CPENTv2 Scripts/Module 03 Open Source Intelligence (OSINT) and Attack Surface Mapping/** location. To do this, you first need to convert it into Unix format by executing the **dos2unix Domain_OSINT.sh** command and then running the Shell script.
2. Edit the target domain name in the script in **Domain_OSINT.sh** placed at **CPENTv2 Pen Testing Resources/CPENTv2 Scripts/Module 03 Open Source Intelligence (OSINT) and Attack Surface Mapping/** and replace **microsoft.com** with **certifiedhacker.com**.
3. Launch a terminal and acquire root privileges by executing **sudo su** command. (When prompted for a password, type **toor**).



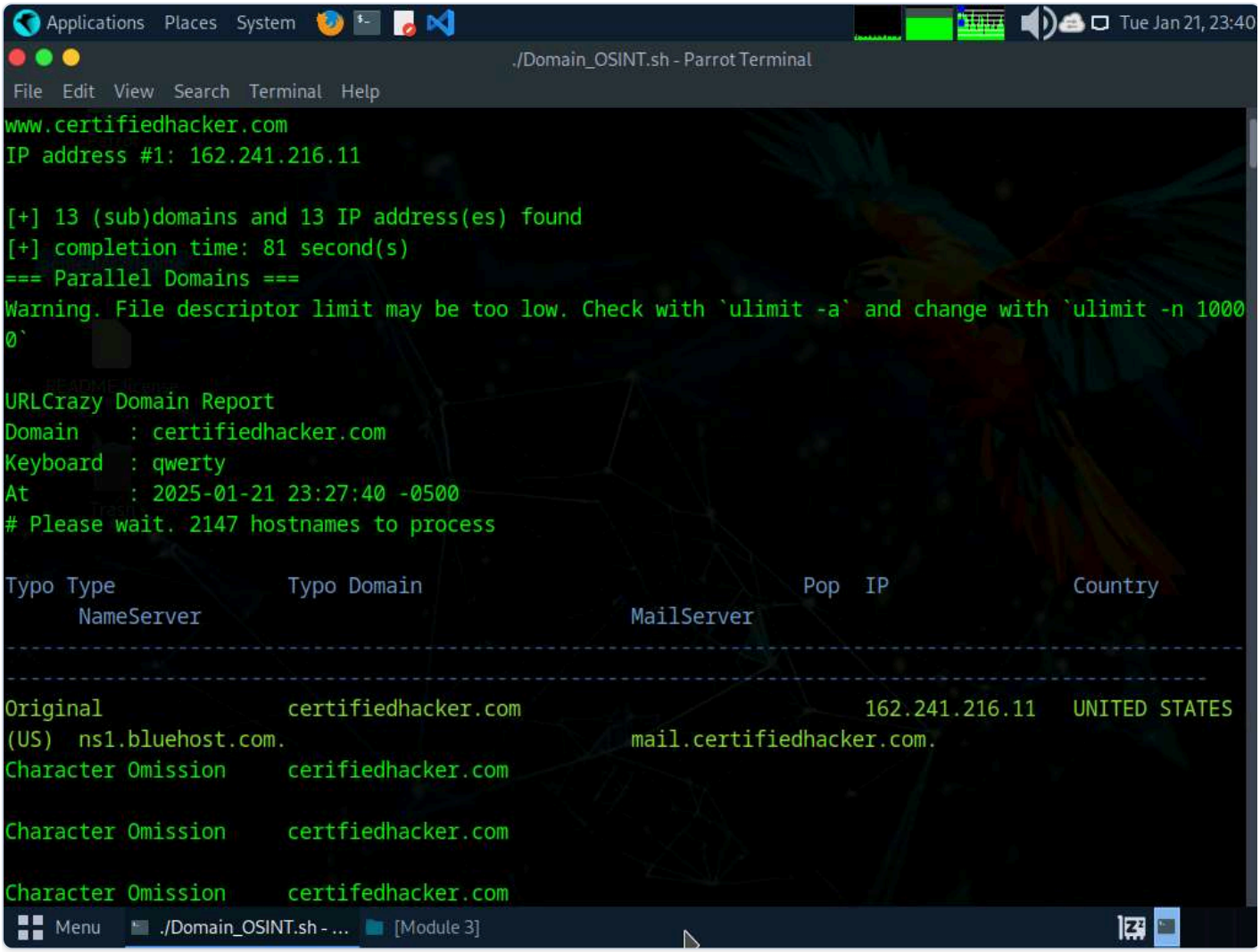
1. In the terminal window, use **dos2unix Domain_OSINT.sh** command to convert it into Unix format, type **chmod +x Domain_OSINT.sh** to give execution permissions, and run **./Domain_OSINT.sh**.

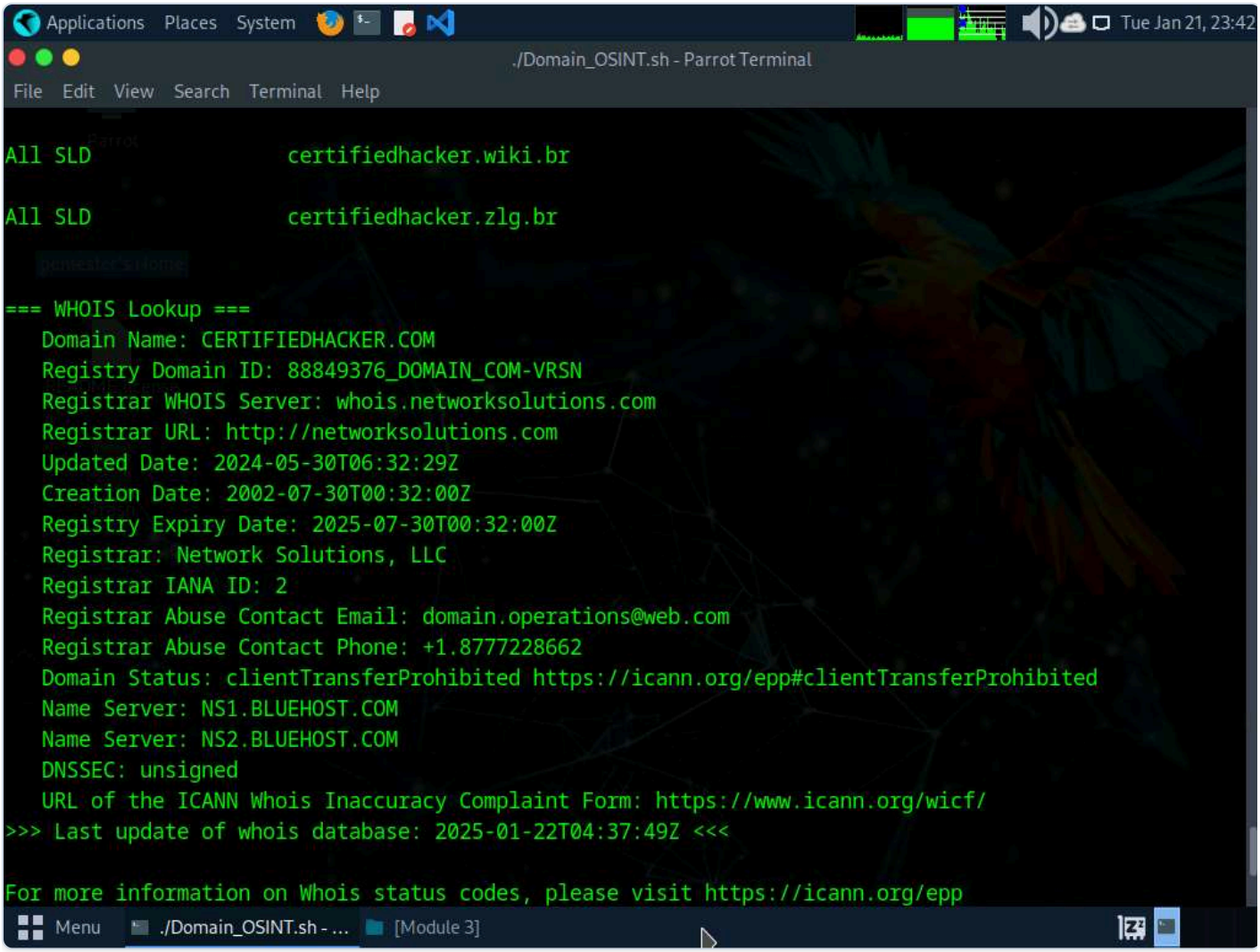


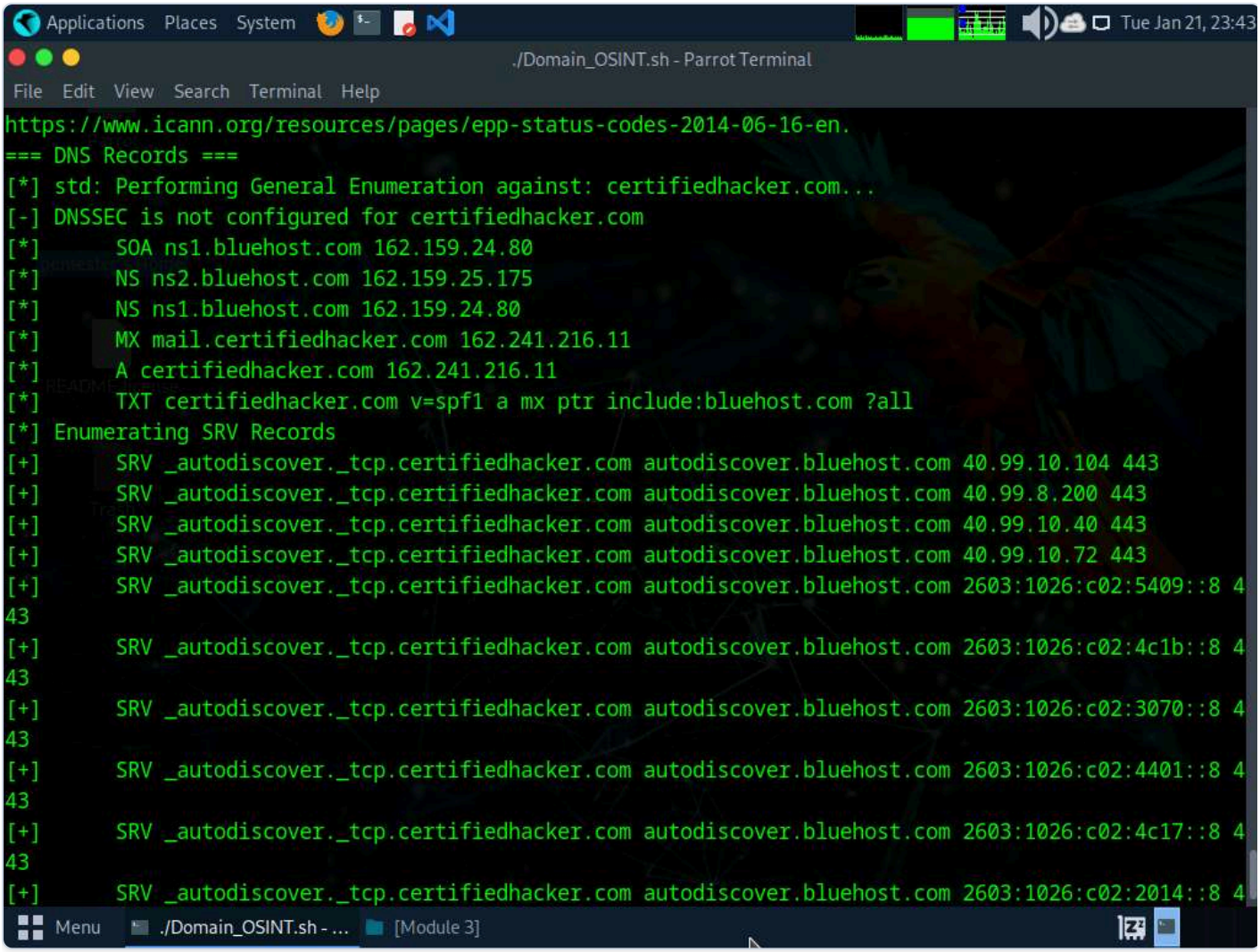
*(Make sure all the necessary tools are installed, such as **dnsmap**, **urlcrazy**, **whois**, and **dnsrecon**).*

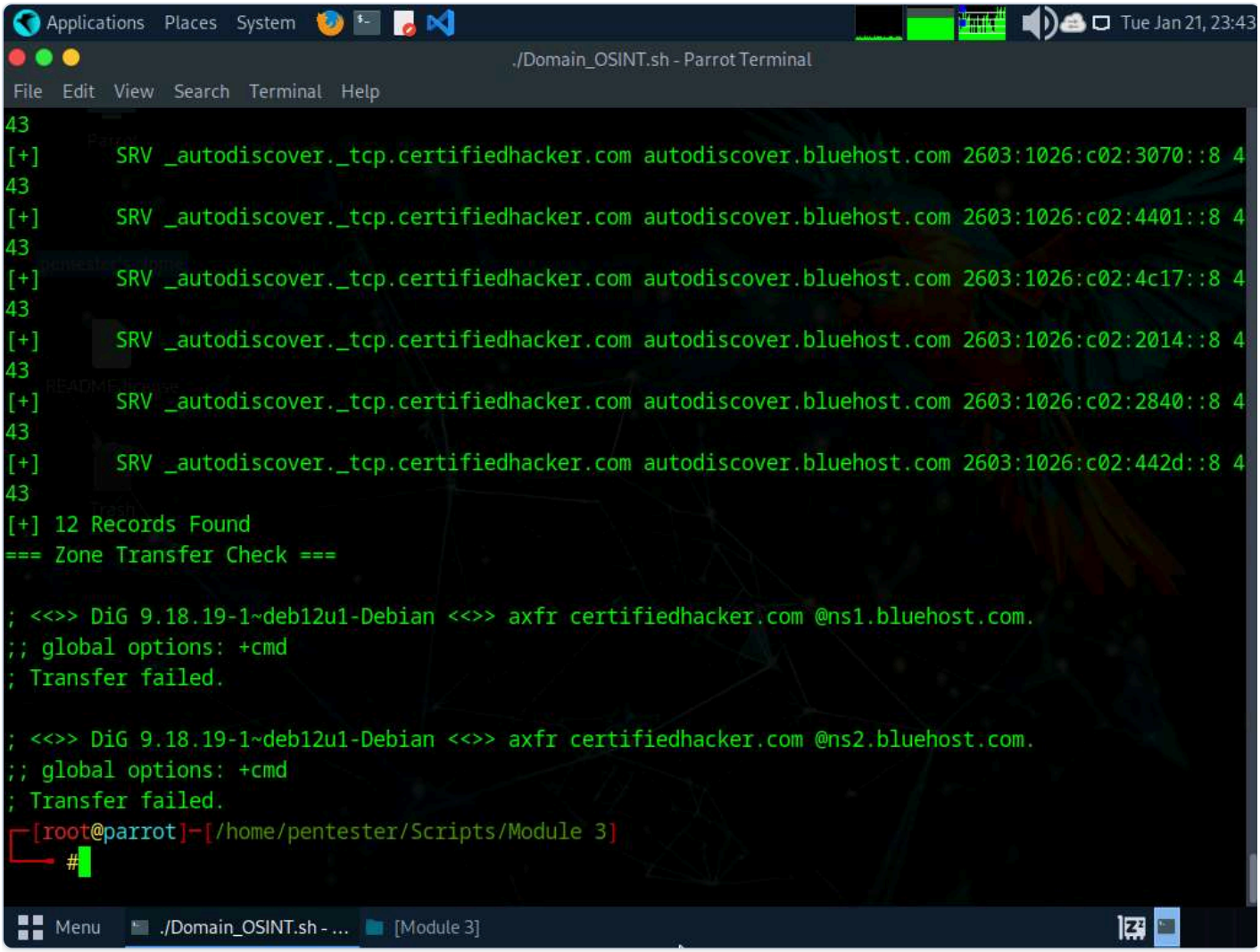
This script automates the Domain's OSINT extraction process. The execution might take some time and will generate the output organized in labeled sections:

- Subdomains
- Parallel Domains
- WHOIS Lookup
- DNS Records
- Zone Transfer Check

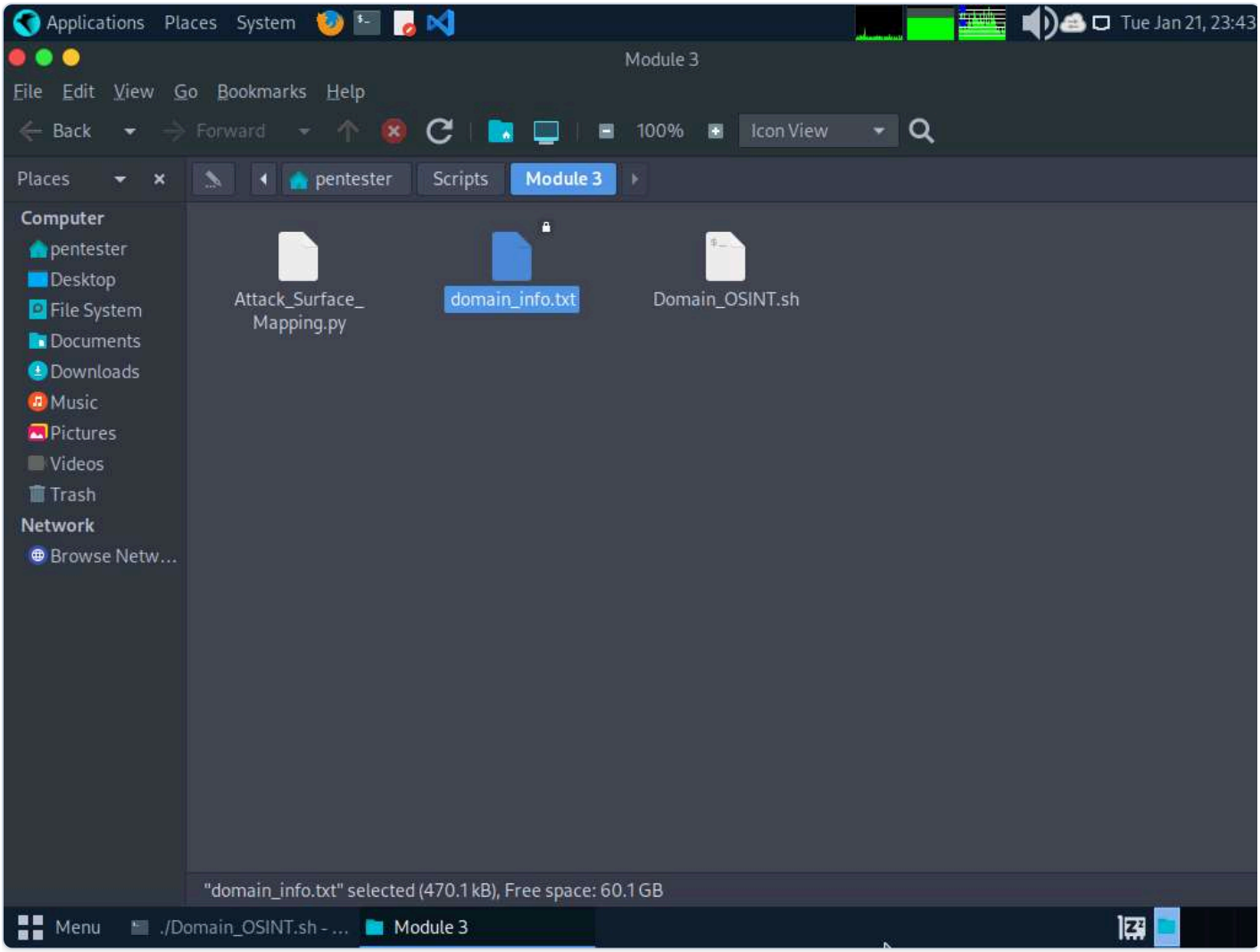

Applications Places System
Tue Jan 21, 23:40
./Domain_OSINT.sh - Parrot Terminal
File Edit View Search Terminal Help
www.certifiedhacker.com
IP address #1: 162.241.216.11
[+] 13 (sub)domains and 13 IP address(es) found
[+] completion time: 81 second(s)
=== Parallel Domains ===
Warning. File descriptor limit may be too low. Check with `ulimit -a` and change with `ulimit -n 1000
0`
URLCrazy Domain Report
Domain : certifiedhacker.com
Keyboard : qwerty
At : 2025-01-21 23:27:40 -0500
Please wait. 2147 hostnames to process
Typo Type Typo Domain Pop IP Country
NameServer MailServer
Original certifiedhacker.com 162.241.216.11 UNITED STATES
(US) ns1.bluehost.com. mail.certifiedhacker.com.
Character Omission cerifiedhacker.com
Character Omission certfiedhacker.com
Character Omission certifedhacker.com
Menu
./Domain_OSINT.sh - ...
[Module 3]

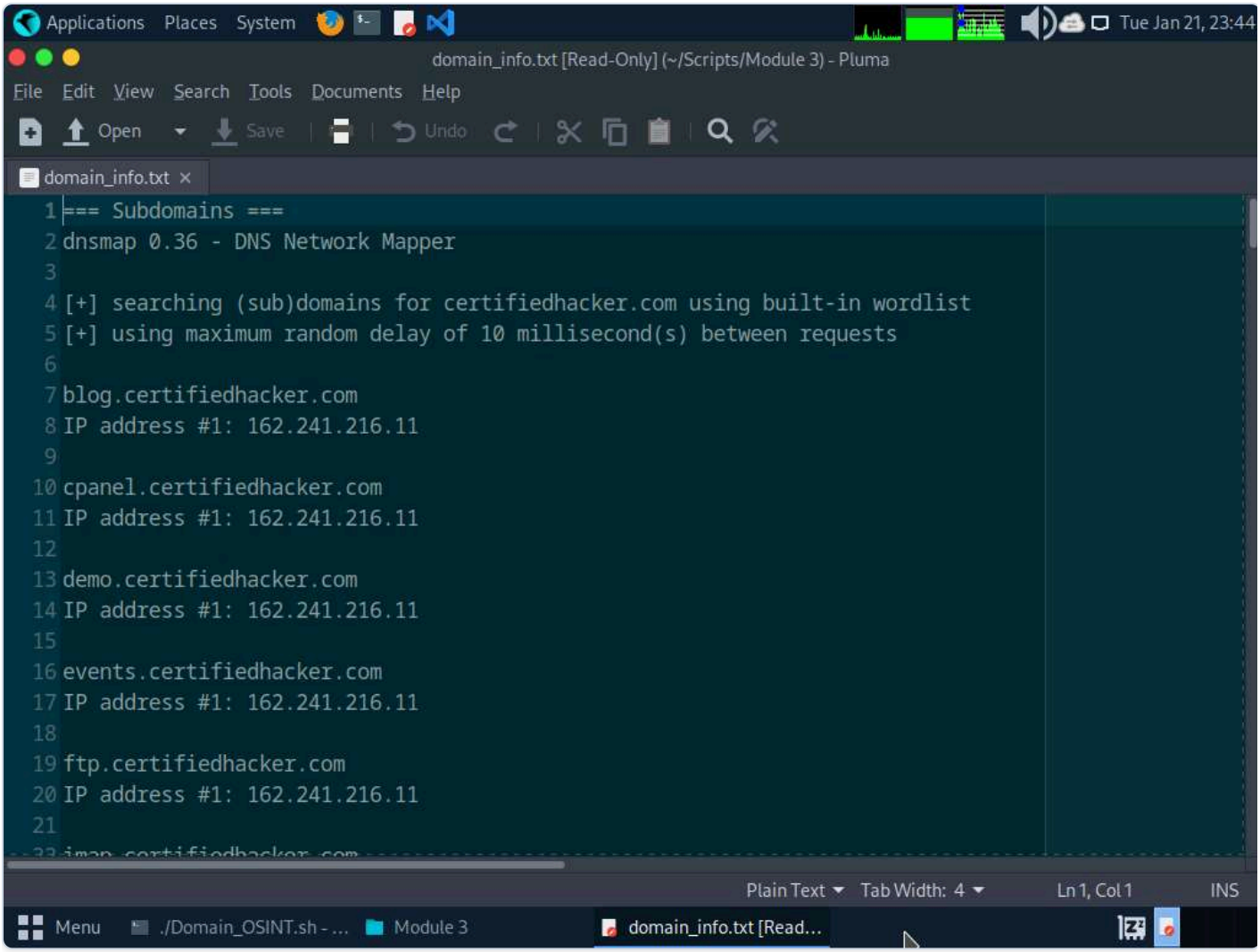

Applications Places System
Tue Jan 21, 23:42
./Domain_OSINT.sh - Parrot Terminal
File Edit View Search Terminal Help
All SLD certifiedhacker.wiki.br
All SLD certifiedhacker.zlg.br
=== WHOIS Lookup ===
Domain Name: CERTIFIEDHACKER.COM
Registry Domain ID: 88849376_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.networksolutions.com
Registrar URL: http://networksolutions.com
Updated Date: 2024-05-30T06:32:29Z
Creation Date: 2002-07-30T00:32:00Z
Registry Expiry Date: 2025-07-30T00:32:00Z
Registrar: Network Solutions, LLC
Registrar IANA ID: 2
Registrar Abuse Contact Email: domain.operations@web.com
Registrar Abuse Contact Phone: +1.8777228662
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: NS1.BLUEHOST.COM
Name Server: NS2.BLUEHOST.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2025-01-22T04:37:49Z <<<
For more information on Whois status codes, please visit https://icann.org/epp
Menu
./Domain_OSINT.sh - ...
[Module 3]


Applications Places System
Tue Jan 21, 23:43
./Domain_OSINT.sh - Parrot Terminal
File Edit View Search Terminal Help
https://www.icann.org/resources/pages/epp-status-codes-2014-06-16-en.
=== DNS Records ===
[*] std: Performing General Enumeration against: certifiedhacker.com...
[-] DNSSEC is not configured for certifiedhacker.com
[*] SOA ns1.bluehost.com 162.159.24.80
[*] NS ns2.bluehost.com 162.159.25.175
[*] NS ns1.bluehost.com 162.159.24.80
[*] MX mail.certifiedhacker.com 162.241.216.11
[*] A certifiedhacker.com 162.241.216.11
[*] TXT certifiedhacker.com v=spf1 a mx ptr include:bluehost.com ?all
[*] Enumerating SRV Records
[+] SRV _autodiscover._tcp.certifiedhacker.com autodiscover.bluehost.com 40.99.10.104 443
[+] SRV _autodiscover._tcp.certifiedhacker.com autodiscover.bluehost.com 40.99.8.200 443
[+] SRV _autodiscover._tcp.certifiedhacker.com autodiscover.bluehost.com 40.99.10.40 443
[+] SRV _autodiscover._tcp.certifiedhacker.com autodiscover.bluehost.com 40.99.10.72 443
[+] SRV _autodiscover._tcp.certifiedhacker.com autodiscover.bluehost.com 2603:1026:c02:5409::8 4
43
[+] SRV _autodiscover._tcp.certifiedhacker.com autodiscover.bluehost.com 2603:1026:c02:4c1b::8 4
43
[+] SRV _autodiscover._tcp.certifiedhacker.com autodiscover.bluehost.com 2603:1026:c02:3070::8 4
43
[+] SRV _autodiscover._tcp.certifiedhacker.com autodiscover.bluehost.com 2603:1026:c02:4401::8 4
43
[+] SRV _autodiscover._tcp.certifiedhacker.com autodiscover.bluehost.com 2603:1026:c02:4c17::8 4
43
[+] SRV _autodiscover._tcp.certifiedhacker.com autodiscover.bluehost.com 2603:1026:c02:2014::8 4
Menu
./Domain_OSINT.sh - ...
[Module 3]



1. This script also saves the output in a text file with the name **domain_info.txt**.


Applications
Places
System
Tue Jan 21, 23:43
Module 3
File Edit View Go Bookmarks Help
Back
Forward
100%
Icon View
Places
pentester
Scripts
Module 3
Computer
pentester
Desktop
File System
Documents
Downloads
Music
Pictures
Videos
Trash
Network
Browse Netw...
Attack_Surface_Mapping.py
domain_info.txt
Domain_OSINT.sh
"domain_info.txt" selected (470.1 kB), Free space: 60.1 GB
Menu
./Domain_OSINT.sh - ...
Module 3



This concludes the demonstration of using Scripts and AI Tools to automate OSINT. Close all open windows.

> **IMPORTANT:** ❓ **Question 3.1.4.1** On the Parrot Security machine, leverage scripts and AI tools to integrate and automate OSINT. Execute the **Domain_OSINT.sh** script located at **CPENTv2 Pen Testing Resources/CPENTv2 Scripts/Module 03 Open Source Intelligence (OSINT) and Attack Surface Mapping/**, and record the Registrar IANA ID obtained from the Whois lookup. [!SUCCESS] ✅ **Answer:** **292**